Facultad de Ingeniería y Arquitectura · EP Ingeniería de Sistemas

Lenguaje de Programación II

- **Alumno: Kenny Misael Inciso Inciso**
- **Rama: `feature/seguridad-spa-pruebas-<Inciso>`**
- **Backend: Pharma Backend and Pharma Frontend seguro (sesión 11)**

Actividad Autónoma — Sesión 11

Pruebas de la SPA segura, aviso previo a la expiración y página «Mi cuenta»

Unidad	II. Frontend SPA empresarial seguro	Sesión	11 · 22 de octubre de 2026
Modalidad	Individual, sin acompañamiento docente	Plazo	Hasta el 28 de octubre de 2026, 23:59
Entrega	Aula virtual + repositorio Git	Puntaje	20 puntos (evaluación de sesión)
Docente	Reyna Barreto Benjamin David	Ciclo	IV · Semestre 2026-2

1. De dónde partimos

En la actividad práctica (Reto 01) PharmaSoft aprendió a iniciar sesión, enviar el token en cada petición, proteger sus rutas y mostrar a cada trabajador solo lo que le corresponde. Pero todavía hay preguntas sin responder: ¿qué ocurre si dos pestañas están abiertas y en una se cierra la sesión? ¿Y si el backend responde 403 en una acción que el menú sí mostraba? ¿Es justo que la vendedora pierda una venta a medio registrar porque el token venció sin aviso?

La administradora de la botica pide dos mejoras: que la aplicación **avise un par de minutos antes** de que la sesión venza, y que cada trabajador tenga una página **«Mi cuenta»** donde vea sus datos, sus roles y sus permisos tal como los conoce el servidor.

Reto 02

Prueba sistemáticamente la SPA segura con una matriz de casos medidos, implementa un aviso previo a la expiración de la sesión y construye la página «Mi cuenta» consumiendo `GET /api/v1/auth/me`.

2. Actividad autónoma

Esta actividad extiende el Reto 01 sobre el mismo repositorio. La primera parte es de **verificación**: cada caso tiene una precondición, unos pasos, un resultado esperado y el resultado obtenido. La segunda parte es de **construcción**: dos funcionalidades que siguen la arquitectura que ya conoces (servicio con signals, componente standalone, ruta protegida). Si te bloqueas, revisa la sección 4, «Dudas frecuentes».

Título	Matriz de pruebas de la SPA segura, aviso previo a la expiración y página «Mi cuenta»
Objetivo	Verifica el login, la sesión, los interceptores, los guards y el menú por permisos de PharmaSoft contrastando resultados esperados y obtenidos, e implementa un aviso previo a la expiración del token y una página «Mi cuenta» que consume el endpoint del usuario autenticado, respetando las reglas de seguridad del frontend.
Tiempo estimado	4 a 5 horas
Materiales	Guía práctica de la sesión 11, PharmaSoft (rama `feature/seguridad-frontend-<apellido>`), PharmaBackend seguro de la sesión 10 y las herramientas del desarrollador del navegador (F12).

Preparación

- Crea la rama `feature/seguridad-spa-pruebas-<apellido>` desde tu rama de la práctica.
- Ten abiertas en F12 las pestañas **Red**, **Consola** y **Aplicación → Almacenamiento de sesión**. Marca «Conservar registro» en Red para no perder las peticiones al navegar.
- Ten a mano los cinco usuarios de prueba: `admin`, `vendedor`, `almacen`, `supervisor` e `inactivo`.

Parte A. Matriz de pruebas de la SPA segura (8 puntos)

Construye la matriz con las columnas **ID · Grupo · Usuario · Pasos · Resultado esperado · Resultado obtenido · Estado (Pasa / Falla) · Evidencia**. La matriz debe tener **al menos 20 casos**: los 16 casos base y **al menos 4 propios**, cada uno de un grupo distinto.

D	Grupo	Caso	
L-01	Login	Enviar el formulario vacío y luego solo con el usuario.	Mensajes de validación; ninguna petición en Red.
L-02	Login	Usuario inexistente, contraseña incorrecta y usuario `inactivo`.	El mismo mensaje en los tres casos; la contraseña se borra y el usuario se conserva.
L-03	Login	Pulsar «Ingresar» dos veces seguidas con datos correctos.	Una sola petición `POST /auth/login` (el botón se deshabilita).
L-04	Login	Escribir `/login?returnUrl=https://sitio falso.com` e iniciar sesión.	Va a /inicio, nunca a un sitio externo.
S-01	Sesión	Iniciar sesión, pulsar F5 y luego cerrar y abrir el navegador.	Tras F5 sigue la sesión; tras cerrar el navegador se pide login.
S-02	Sesión	Cambiar `expiraEn` en Almacenamiento de sesión a un instante pasado y pulsar F5.	La sesión guardada se descarta y aparece el login.
S-03	Sesión	Escribir texto que no sea JSON en `pharmasoft.sesion` y pulsar F5.	La SPA no se rompe: muestra el login (try/catch).

S-04	Sesión	Abrir la SPA en dos pestañas y cerrar sesión en una; navegar en la otra.	Registra qué ocurre y explícalo en el informe (pista: sessionStorage es por pestaña).
I-01	Interceptor	Revisar en Red `GET /productos`, `POST /auth/login` y una petición a otro dominio (por ejemplo, una fuente o imagen externa).	Solo las peticiones a la API llevan `Authorization: Bearer`.
I-02	Interceptor	Con sesión iniciada, detener el backend y navegar a Productos.	Mensaje de error de conexión; la sesión no se cierra (no es un 401).

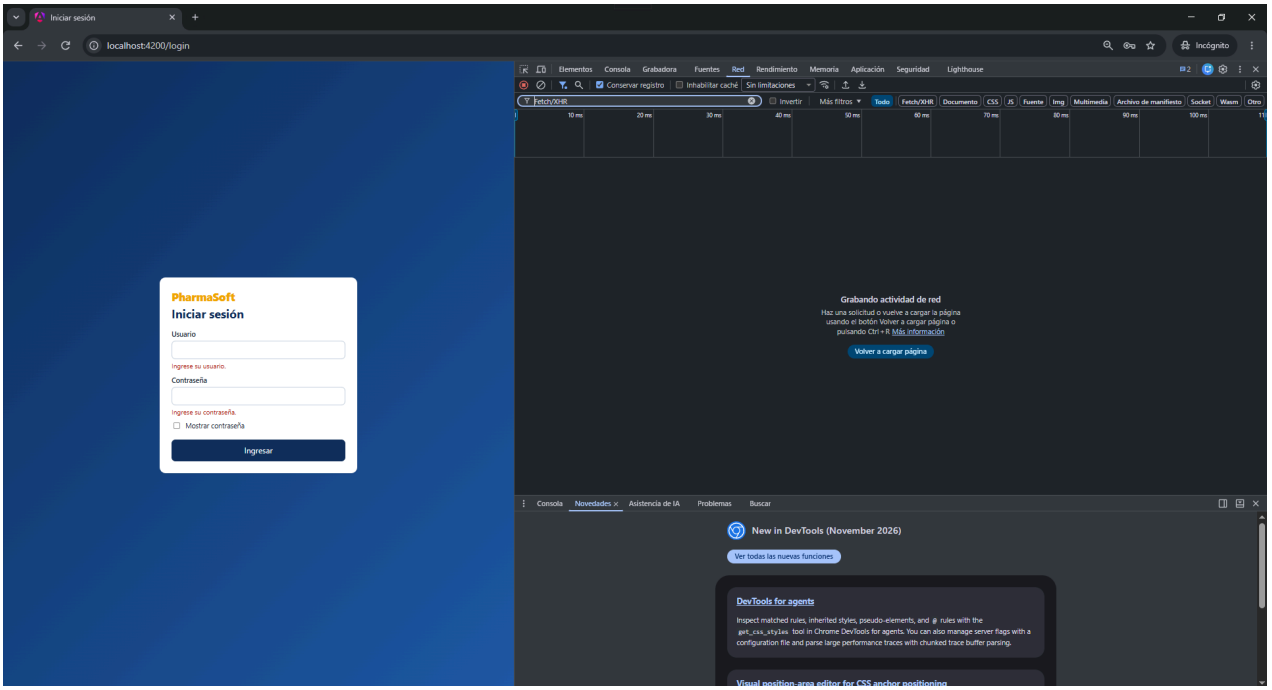
D	Grupo	Caso	
I-03	Interceptor	Alterar un carácter del token y abrir Ventas.	401; login con «Su sesión expiró» y `returnUrl=%2Fventas`.
G-01	Guards	Sin sesión, escribir `/productos/1/editar`, `/ventas/nueva` e `/inicio`.	Login con el `returnUrl` de cada ruta.
G-02	Guards	VENDEDOR escribe `/categorias/nuevo`, `/productos/1/editar`; ALMACENERO escribe `/ventas/nueva`.	«403 · Acceso denegado» en los tres casos.
M-01	Menú y acciones	Iniciar sesión con los cuatro usuarios activos y comparar menú y botones.	Cada usuario ve exactamente lo que indica su tabla de permisos.
M-02	Menú y acciones	Cerrar sesión como ADMIN e iniciar como ALMACENERO sin recargar.	El menú cambia sin F5 (computed).
E-01	401 / 403	Como VENDEDOR, quitar `*appSiPermiso` del botón «Dar de baja» (o usar la consola) y ejecutar la acción.	El backend responde 403; la SPA muestra el mensaje y la sesión continúa.

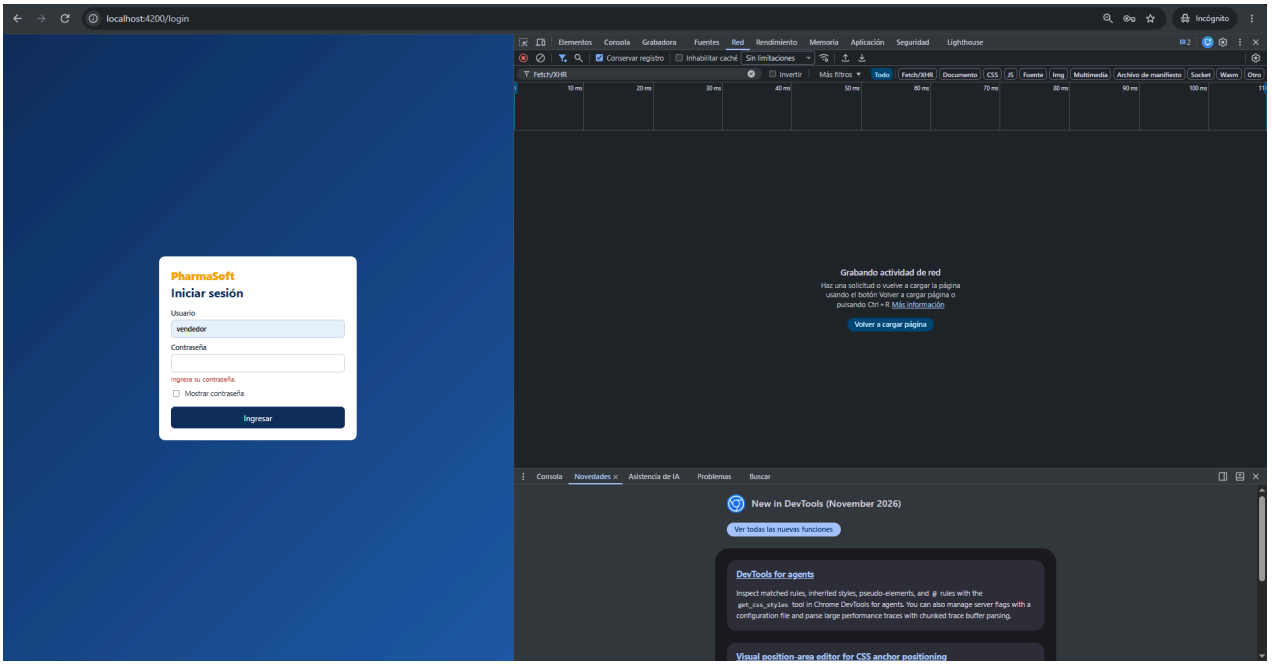
Cómo registrar la evidencia

Cada caso necesita una captura donde se vea la URL del navegador y, cuando corresponda, la pestaña Red (método, código y encabezado `Authorization`) o el Almacenamiento de sesión. Nombra las capturas con el ID: `I-03_red.png`. En las capturas tapa el token completo: basta con que se vean los primeros caracteres.

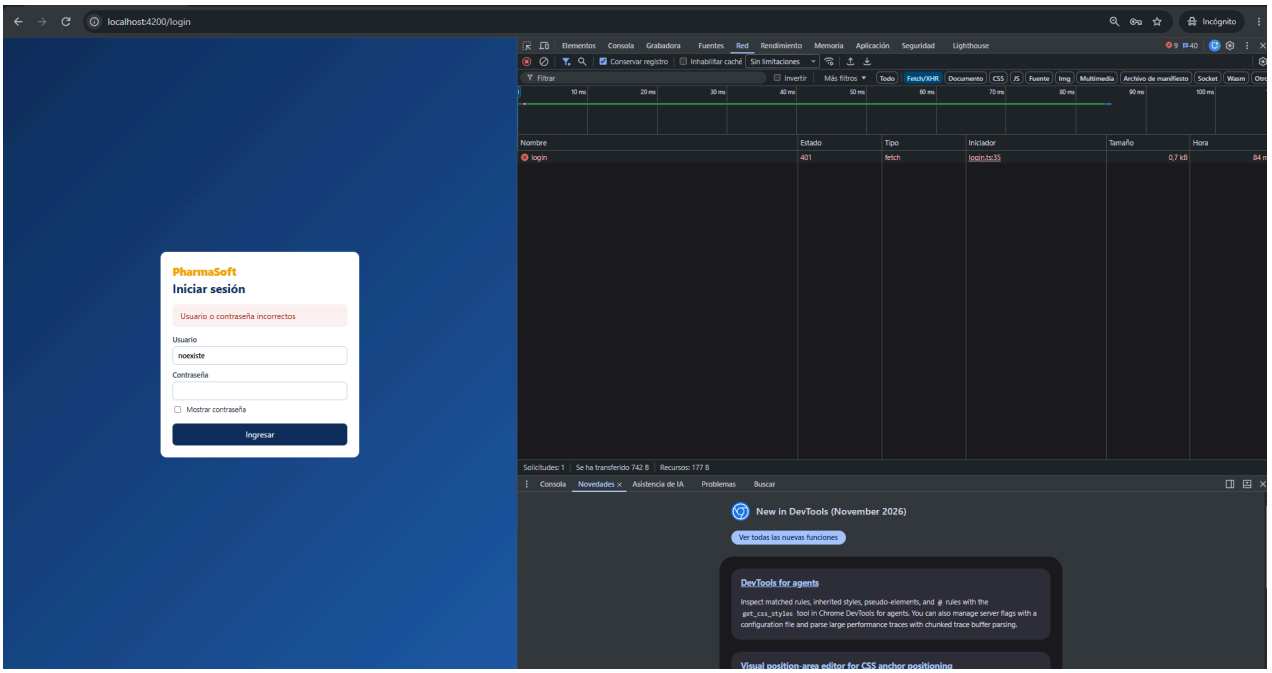
Prueba 1
Usuario / token: L-01 Login
Petición: Enviar el formulario vacío y luego solo con el usuario

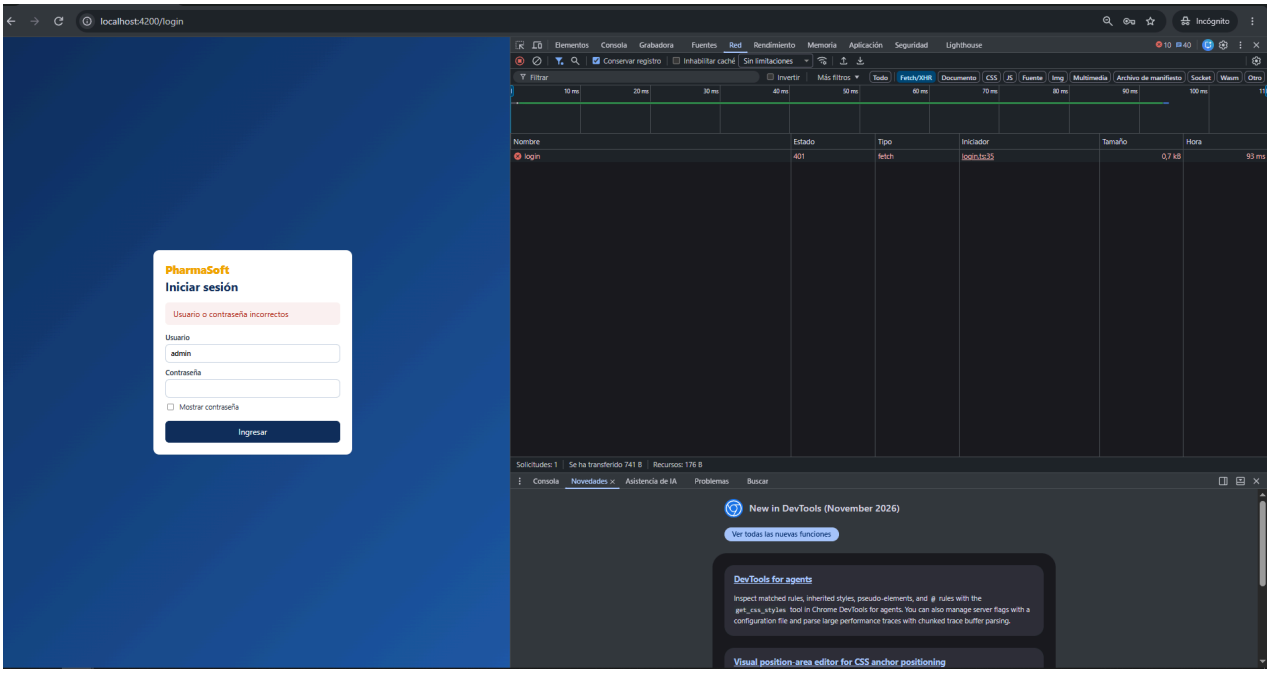
Resultado esperado: Mensajes de validación; ninguna petición en Red.

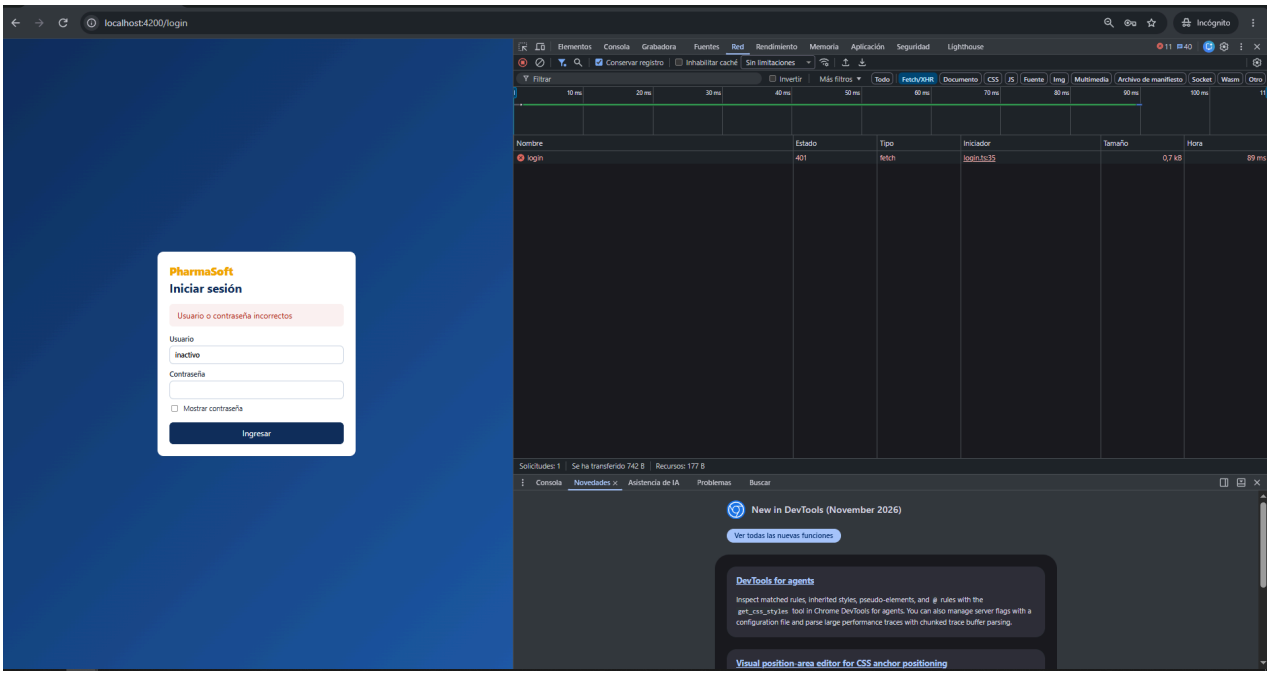




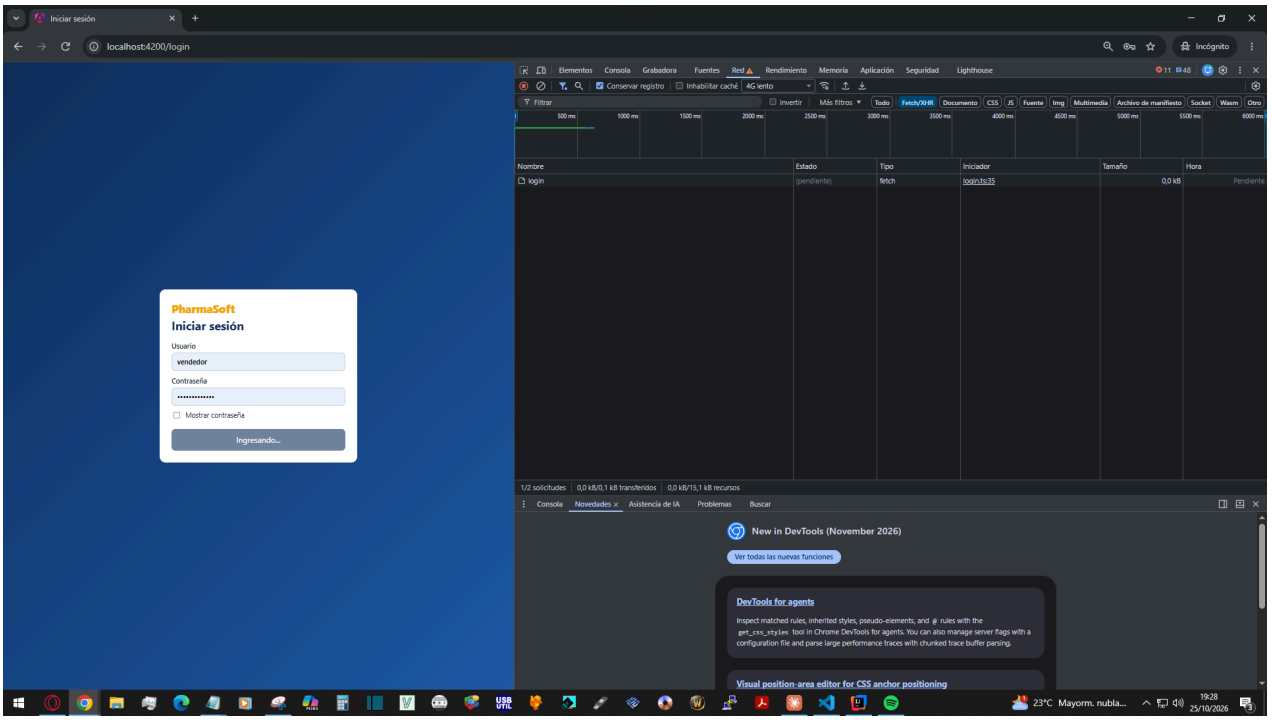
Prueba 2
Usuario / token: L-02 Login
Petición: Usuario inexistente, contraseña incorrecta y usuario `inactivo`
Resultado esperado: El mismo mensaje en los tres casos; la contraseña se borra y el usuario se conserva.

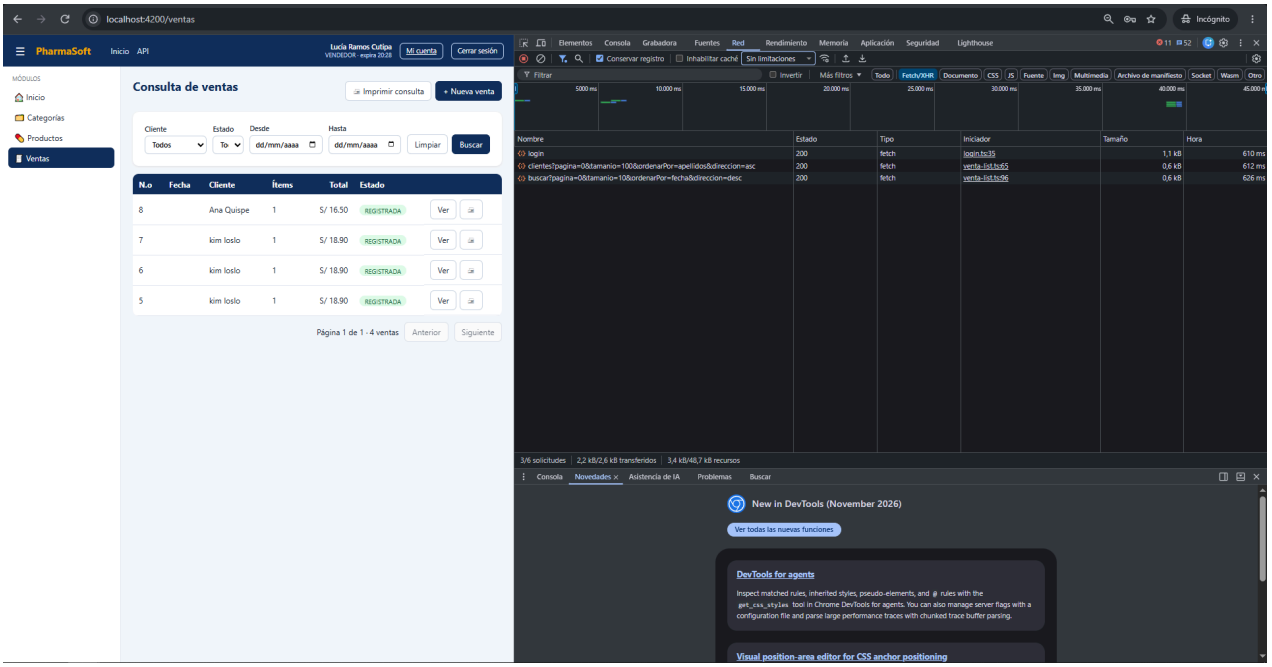






Prueba 3
Usuario / token: L-03 Login
Petición: Pulsar «Ingresar» dos veces seguidas con datos correctos.
Resultado esperado: Una sola petición `POST /auth/login` (el botón se deshabilita).


Iniciar sesión
localhost:4200/login
Incógnito
PharmaSoft
Iniciar sesión
Usuario
vendedor
Contraseña
Mostrar contraseña
Ingresando...
Elementos
Consola
Grabadora
Fuentes
Red
Rendimiento
Memoria
Aplicación
Seguridad
Lighthouse
Nombre
Estado
Tipo
Iniciador
Tamaño
Hora
login
(pendiente)
fetch
login.ts:35
0,0 kB
Pendiente
1/2 solicitudes
0,0 kB/0,1 kB transferidos
0,0 kB/15,1 kB recursos
Consola
Novedades
Asistencia de IA
Problemas
Buscar
New in DevTools (November 2026)
Ver todas las nuevas funciones
DevTools for agents
Visual position-area editor for CSS anchor positioning
23°C Mayorm. nubla...
19:28
25/10/2026

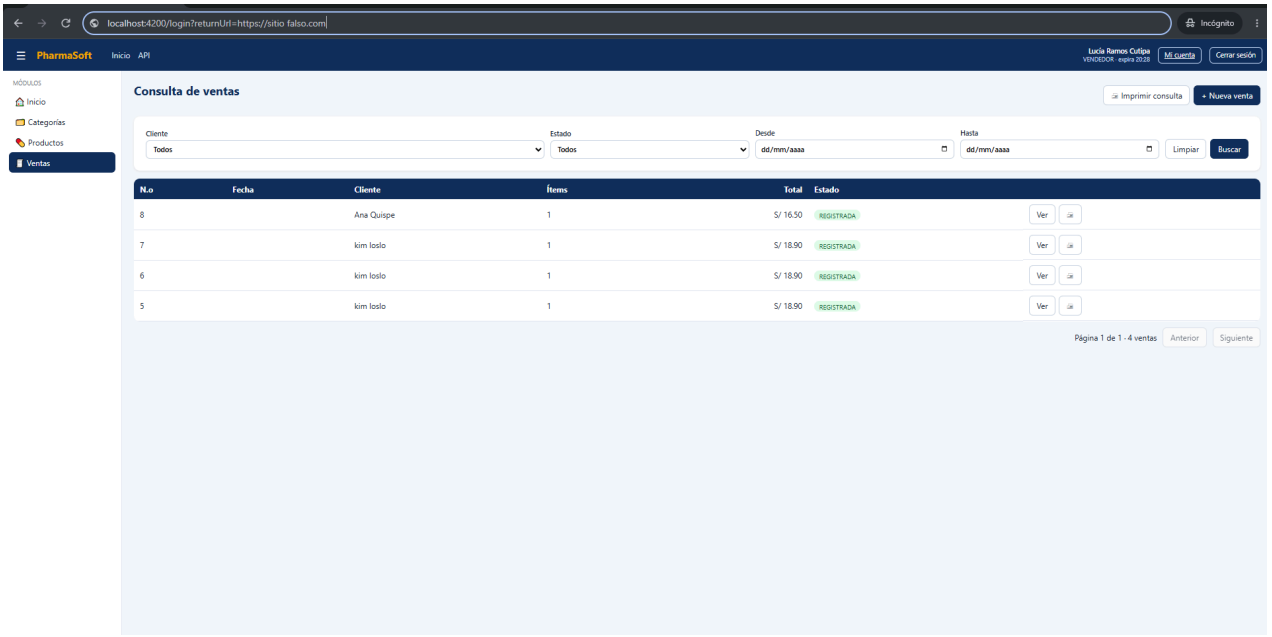


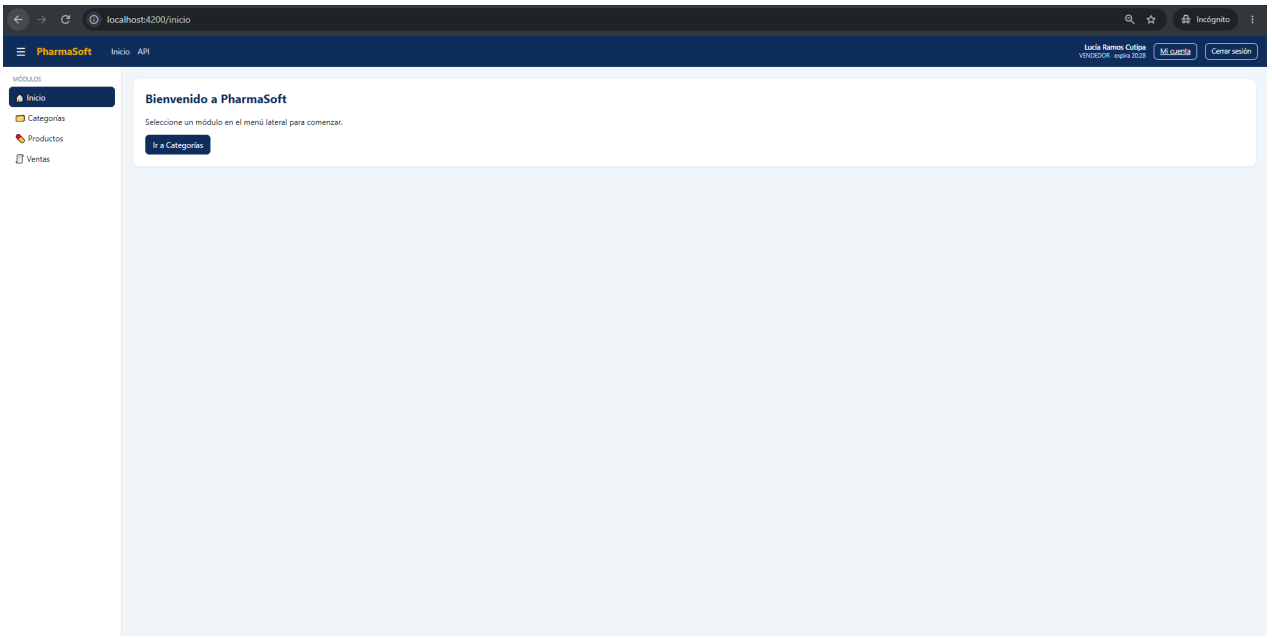
Prueba 4

Usuario / token: L-05 Login

Petición: Escribir `/login?returnUrl=https://sitio falso.com` e iniciar sesión.

Resultado esperado: Va a /inicio, nunca a un sitio externo.



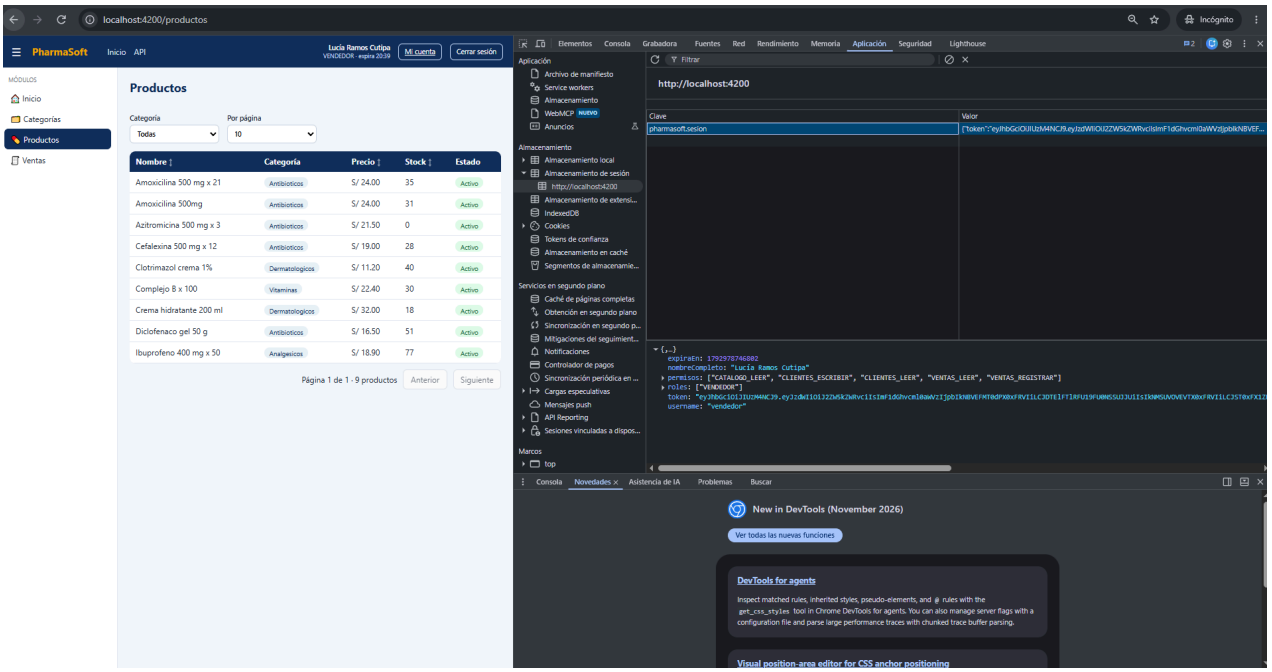


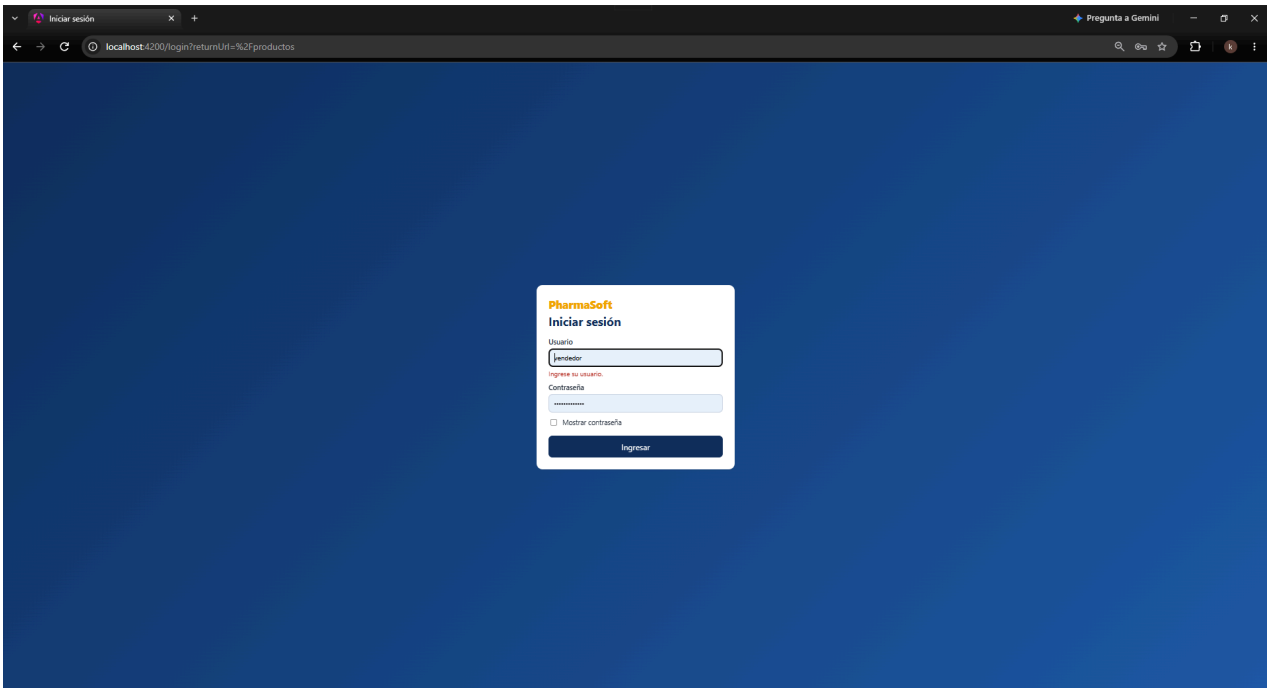
Prueba 5

Usuario / token: S-01 Sesion

Petición: Iniciar sesión, pulsar F5 y luego cerrar y abrir el navegador

Resultado esperado: Tras F5 sigue la sesión; tras cerrar el navegador se pide login


localhost:4200/productos
PharmaSoft
Inicio · API
Lucía Ramos Cutipa
VENDEDOR · expira 20:59
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Ventas
Productos
Categoría
Todas
Por página
10
Nombre
Categoría
Precio
Stock
Estado
Amoxicilina 500 mg x 21 Antibióticos S/ 24.00 35 Activo
Amoxicilina 500mg Antibióticos S/ 24.00 31 Activo
Azitromicina 500 mg x 3 Antibióticos S/ 21.50 0 Activo
Cefalexina 500 mg x 12 Antibióticos S/ 19.00 28 Activo
Clotrimazol crema 1% Dermatológicos S/ 11.20 40 Activo
Complejo B x 100 Vitaminas S/ 22.40 30 Activo
Crema hidratante 200 ml Dermatológicos S/ 32.00 18 Activo
Diclofenaco gel 50 g Antibióticos S/ 16.50 51 Activo
Ibuprofeno 400 mg x 50 Analgésicos S/ 18.90 77 Activo
Página 1 de 1 · 9 productos
Anterior
Siguiente
Elementos
Consola
Grabadora
Fuentes
Red
Rendimiento
Memoria
Aplicación
Seguridad
Lighthouse
Aplicación
Archivo de manifiesto
Service workers
Almacenamiento
WebMCP NUEVO
Anuncios
Almacenamiento
Almacenamiento local
Almacenamiento de sesión
http://localhost:4200
Almacenamiento de extensi...
IndexedDB
Cookies
Tokens de confianza
Almacenamiento en caché
Segmentos de almacenamie...
Servicios en segundo plano
Caché de páginas completas
Obtención en segundo plano
Sincronización en segundo p...
Mitigaciones del seguiment...
Notificaciones
Controlador de pagos
Sincronización periódica en ...
Cargas especulativas
Mensajes push
API Reporting
Sesiones vinculadas a dispos...
Marcos
top
http://localhost:4200
Clave
Valor
pharmasoft.sesion
{"token":"eyJhbGciOiJIUzI4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19MRUVSIiwiVkVOVEFTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIl0sImlhdCI6MTc3NzI4MDAwMCwiZXhwIjoxNzc3MzY2NDAwfQ.abc123","expiraEn":1777367400000,"nombreCompleto":"Lucía Ramos Cutipa","permisos":["CATALOGO_LEER","CLIENTES_ESCRIBIR","CLIENTES_LEER","VENTAS_LEER","VENTAS_REGISTRAR"],"roles":["VENDEDOR"],"username":"vendedor"}
Consola
Novedades
Asistencia de IA
Problemas
Buscar
New in DevTools (November 2026)
Ver todas las nuevas funciones
DevTools for agents
Inspect matched rules, inherited styles, pseudo-elements, and @ rules with the get_css_styles tool in Chrome DevTools for agents. You can also manage server flags with a configuration file and parse large performance traces with chunked trace buffer parsing.
Visual position-area editor for CSS anchor positioning

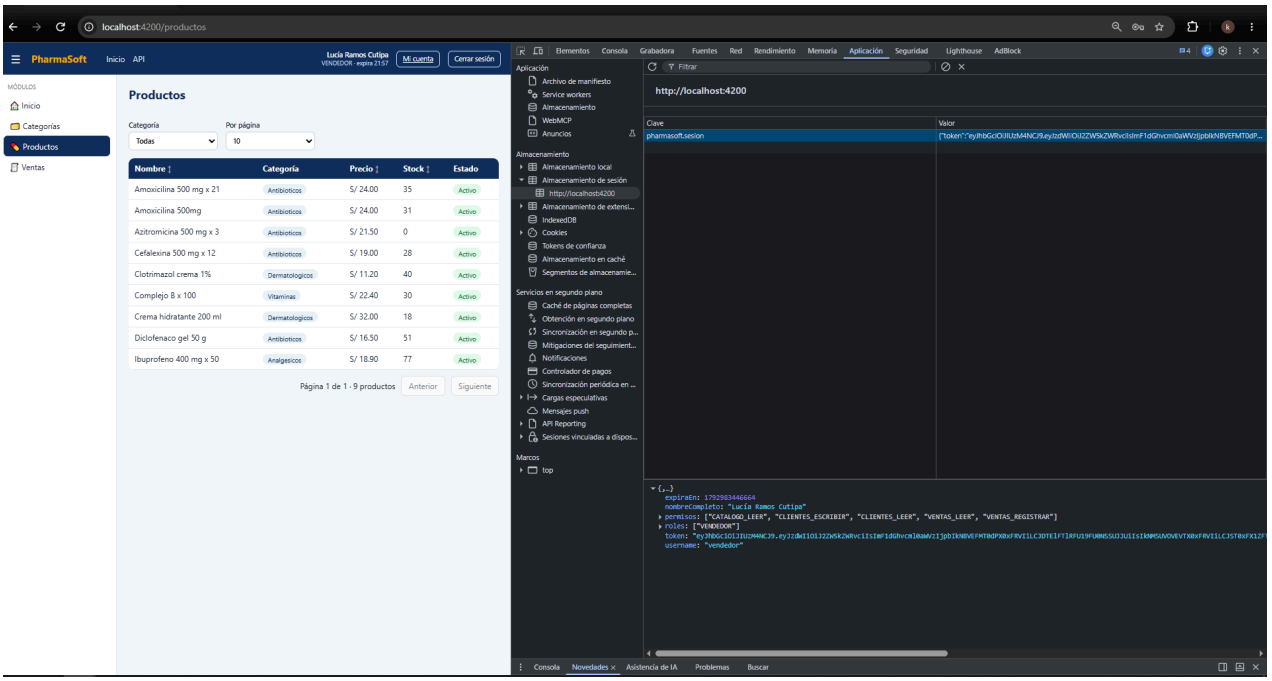

Iniciar sesión
Pregunta a Gemini
localhost:4200/login?returnUrl=%2Fproductos
PharmaSoft
Iniciar sesión
Usuario
vendedor
Ingrese su usuario.
Contraseña
Mostrar contraseña
Ingresar

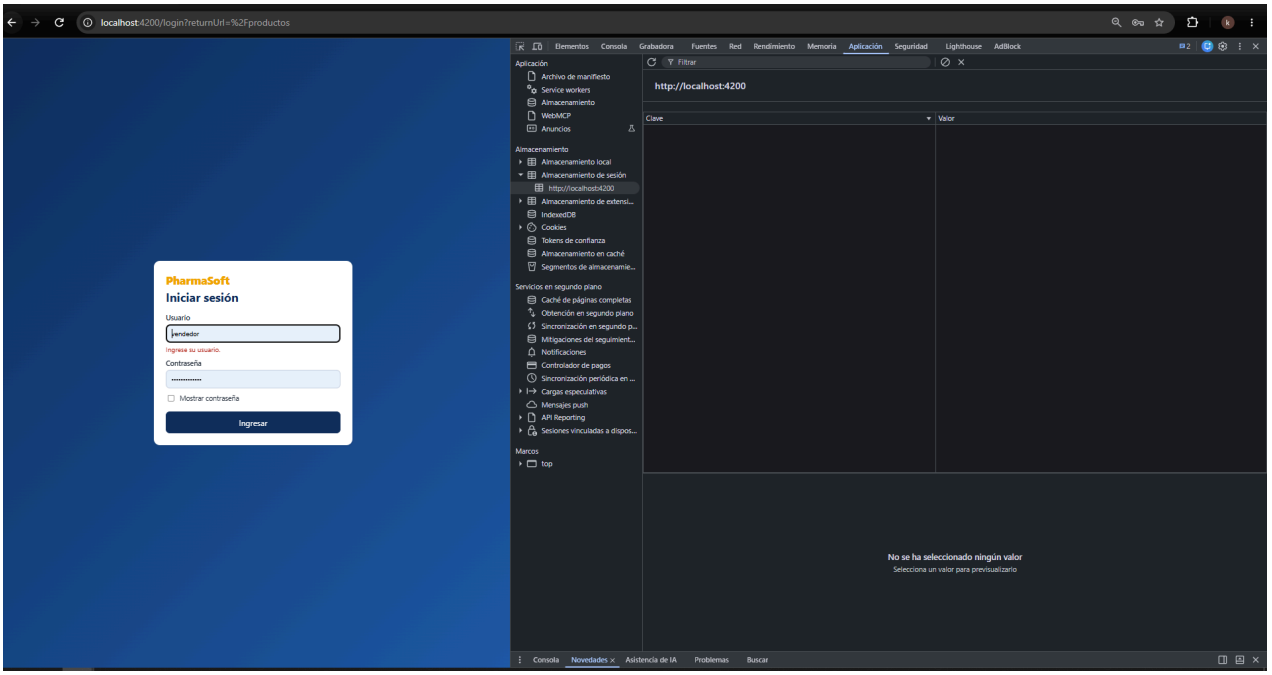
Prueba 6

Usuario / token: S-02 Sesion

Petición: Cambiar `expira En` en Almacenamiento de sesión a un instante pasado y pulsar F5

Resultado esperado: La sesión guardada se descarta y aparece el login


localhost:4200/productos
PharmaSoft
Inicio
API
Lucía Ramos Cutipa
VENDEDOR · expira 21:57
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Ventas
Productos
Categoría
Todas
Por página
10
Nombre
Categoría
Precio
Stock
Estado
Amoxicilina 500 mg x 21
Antibióticos
S/ 24.00
35
Activo
Amoxicilina 500mg
Antibióticos
S/ 24.00
31
Activo
Azitromicina 500 mg x 3
Antibióticos
S/ 21.50
0
Activo
Cefalexina 500 mg x 12
Antibióticos
S/ 19.00
28
Activo
Clotrimazol crema 1%
Dermatológicos
S/ 11.20
40
Activo
Complejo B x 100
Vitaminas
S/ 22.40
30
Activo
Crema hidratante 200 ml
Dermatológicos
S/ 32.00
18
Activo
Diclofenaco gel 50 g
Antibióticos
S/ 16.50
51
Activo
Ibuprofeno 400 mg x 50
Analgésicos
S/ 18.90
77
Activo
Página 1 de 1 · 9 productos
Anterior
Siguiente
Elementos
Consola
Grabadora
Fuentes
Red
Rendimiento
Memoria
Aplicación
Seguridad
Lighthouse
AdBlock
Filtrar
http://localhost:4200
Clave
Valor
pharmasoft.sesion
{"token":"eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX...
Aplicación
Archivo de manifiesto
Service workers
Almacenamiento
WebMCP
Anuncios
Almacenamiento
Almacenamiento local
Almacenamiento de sesión
http://localhost:4200
Almacenamiento de extensi...
IndexedDB
Cookies
Tokens de confianza
Almacenamiento en caché
Segmentos de almacenamie...
Servicios en segundo plano
Caché de páginas completas
Obtención en segundo plano
Sincronización en segundo p...
Mitigaciones del seguiment...
Notificaciones
Controlador de pagos
Sincronización periódica en ...
Cargas especulativas
Mensajes push
API Reporting
Sesiones vinculadas a dispos...
Marcos
top
{,..}
expiraEn: 1792983446664
nombreCompleto: "Lucía Ramos Cutipa"
permisos: ["CATALOGO_LEER", "CLIENTES_ESCRIBIR", "CLIENTES_LEER", "VENTAS_LEER", "VENTAS_REGISTRAR"]
roles: ["VENDEDOR"]
token: "eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVT

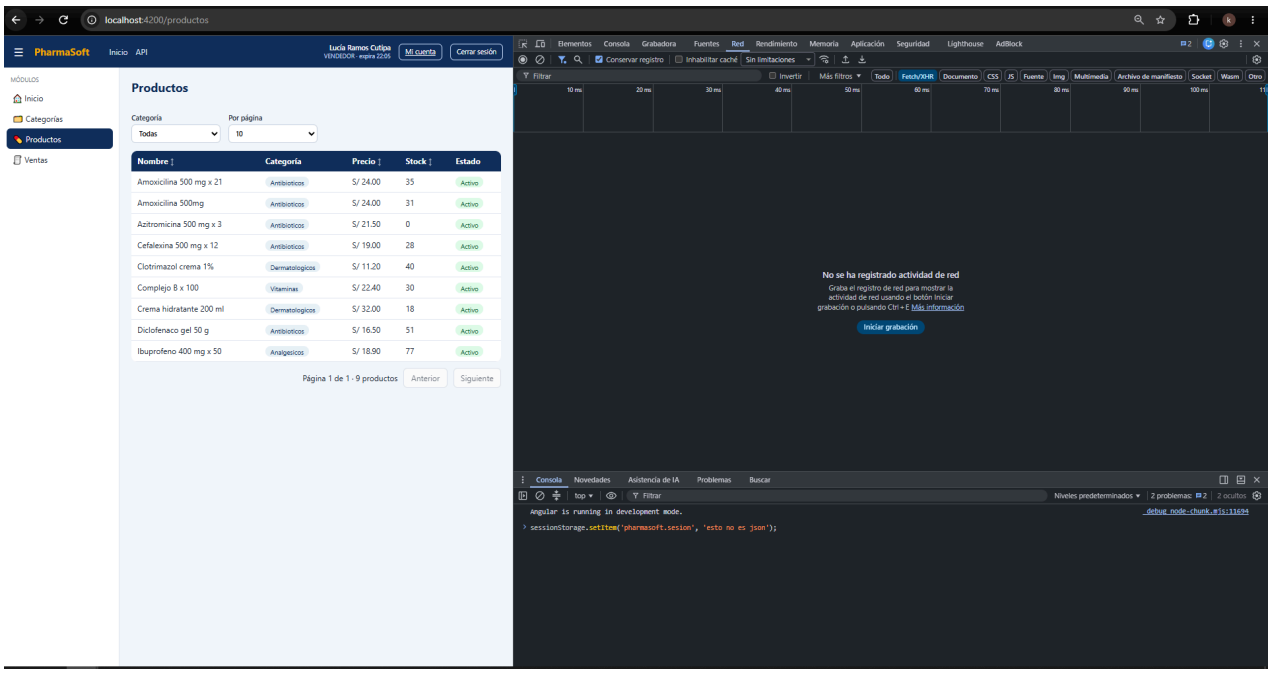


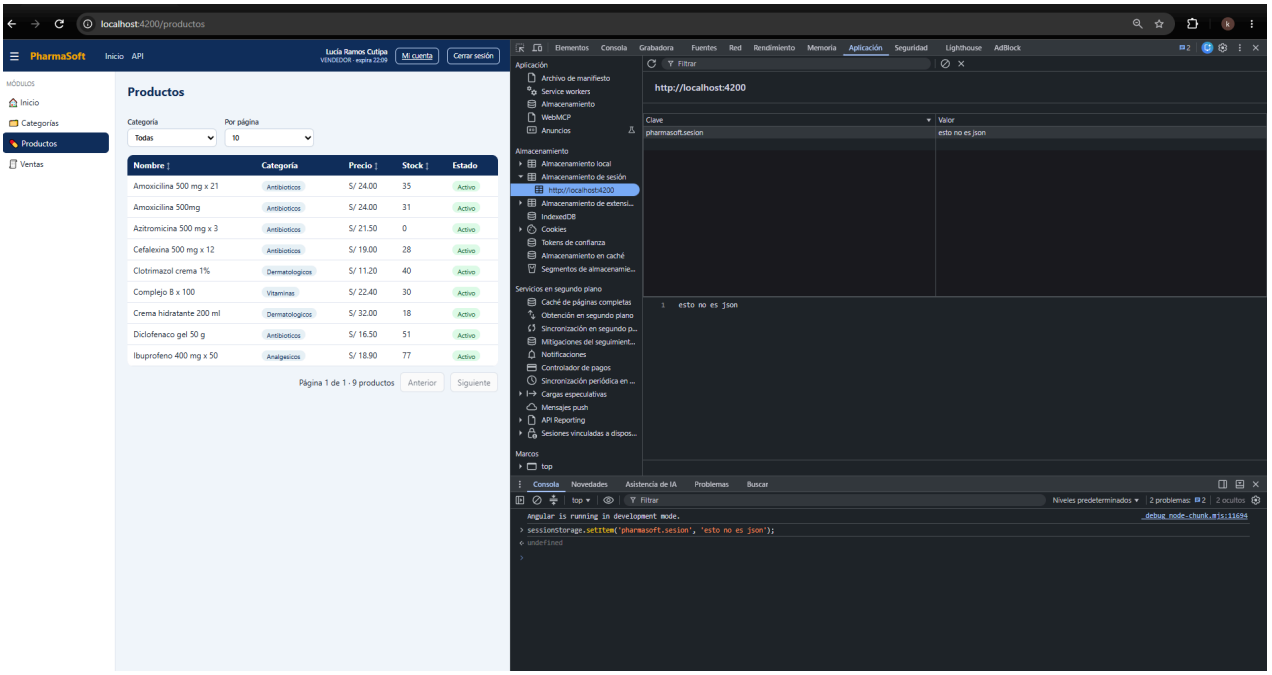
Prueba 7

Usuario / token: S-03 Sesion

Petición: Escribir texto que no sea JSON en `pharmasoft.sesión` y pulsar F5.

Resultado esperado: La SPA no se rompe: muestra el login (try/catch)



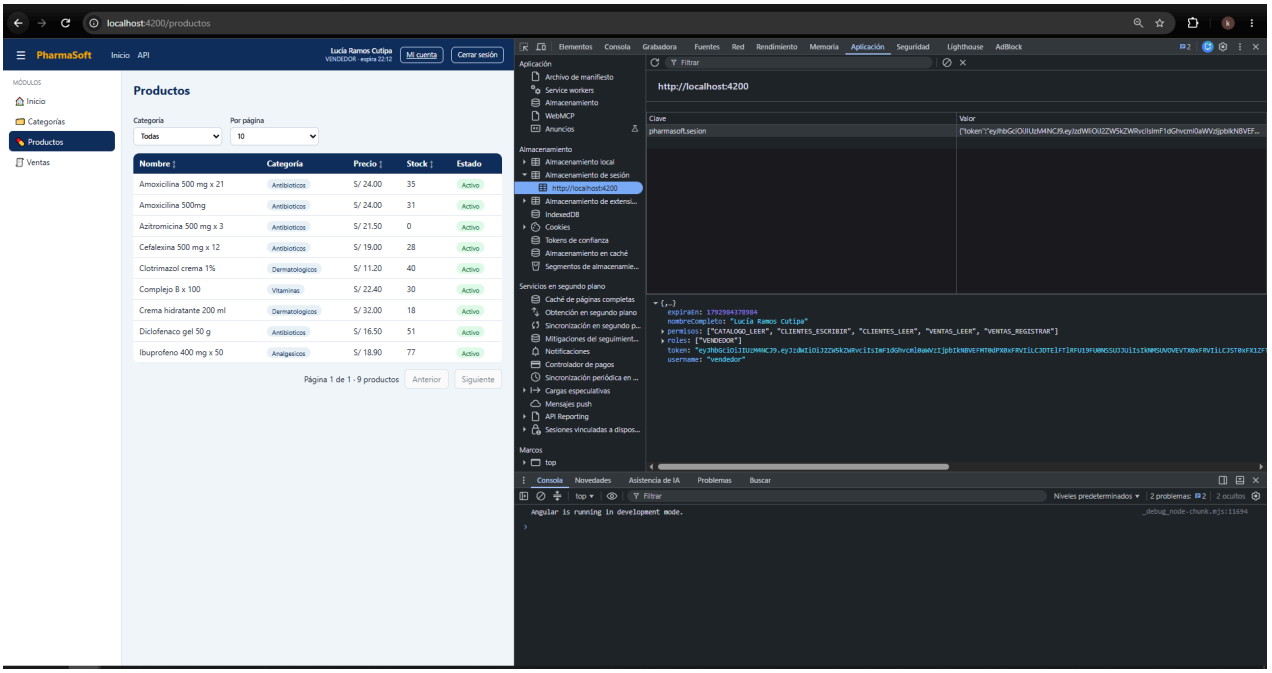


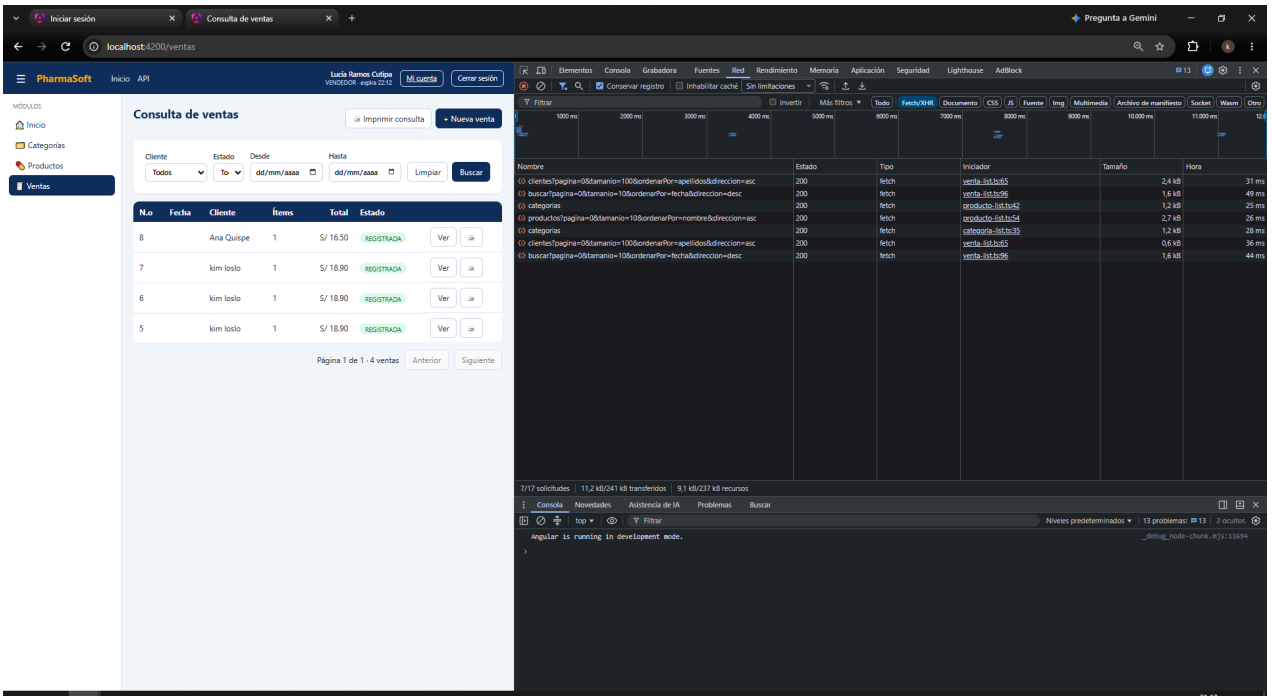
Prueba 8

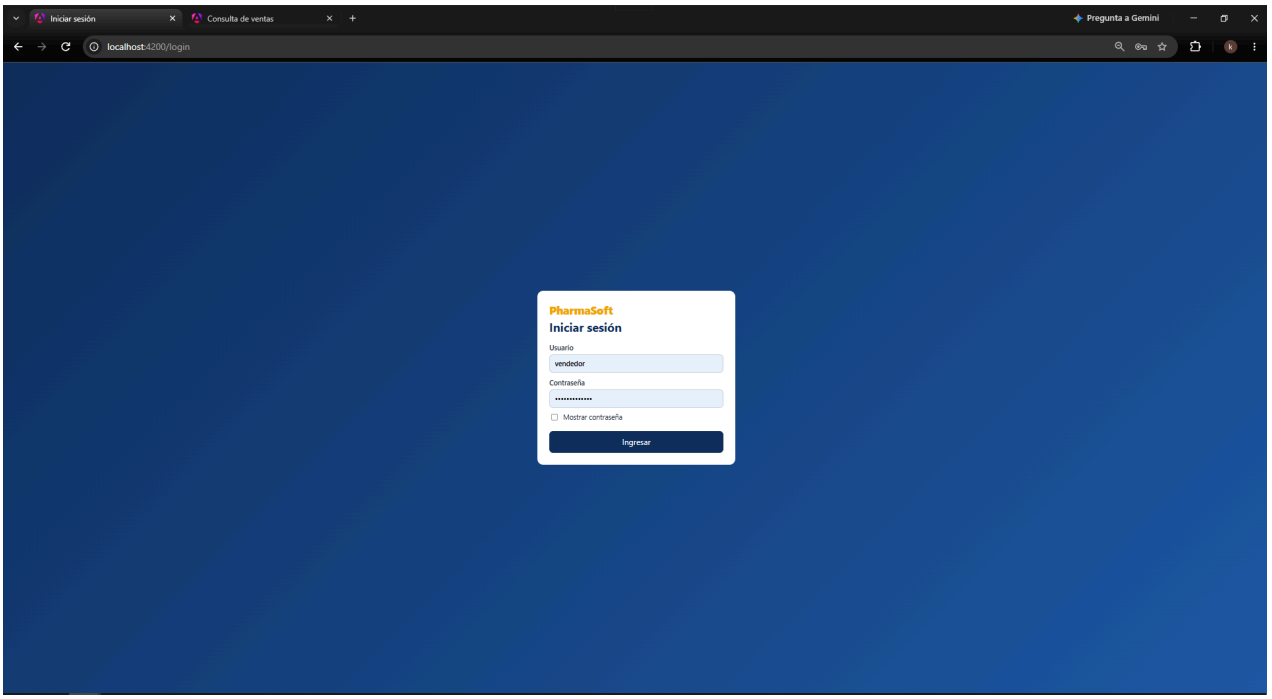
Usuario / token: S-04 Sesion

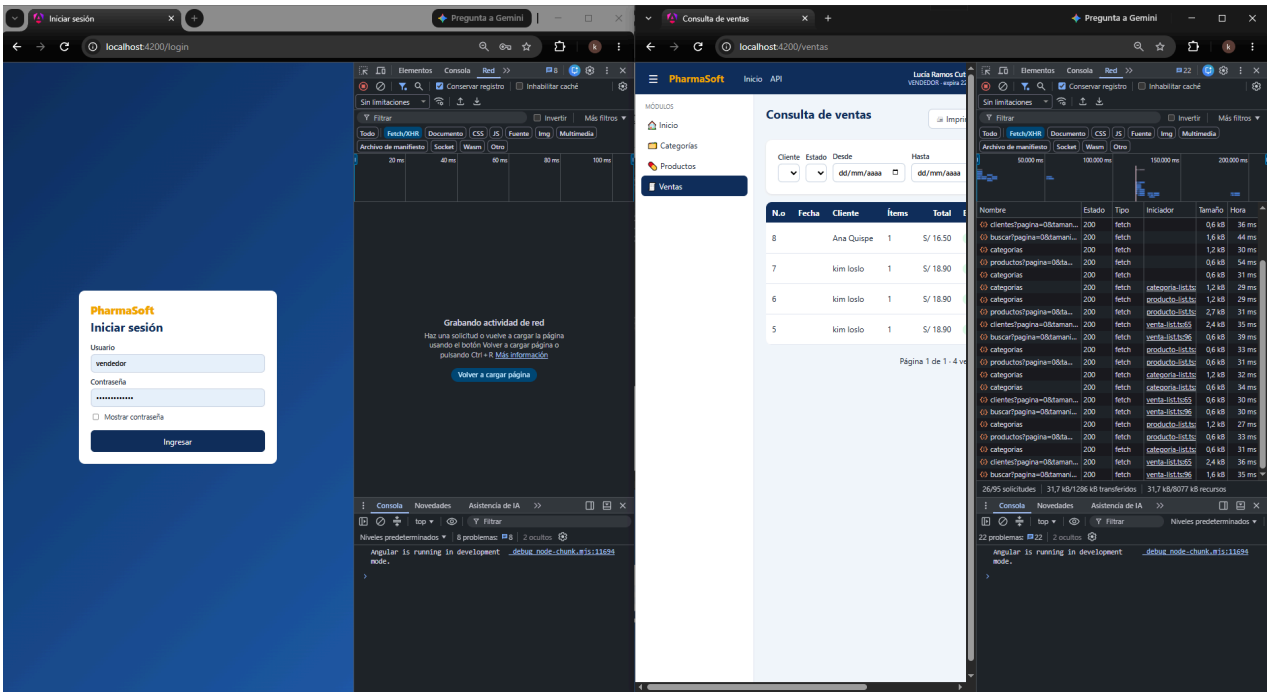
Petición: Abrir la SPA en dos pestañas y cerrar sesión en una; navegar en la otra.

Resultado esperado: Registra qué ocurre y explícalo en el informe (pista: sessionStorage es por pestaña).




Iniciar sesión
Consulta de ventas
Pregunta a Gemini
localhost:4200/ventas
PharmaSoft
Inicio
API
Lucia Ramos Cutipa
VENDEDOR · expira 22:12
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Ventas
Consulta de ventas
Imprimir consulta
+ Nueva venta
Cliente
Estado
Desde
Hasta
Todos
dd/mm/aaaa
Limpiar
Buscar
N.o
Fecha
Cliente
Ítems
Total
Estado
8
Ana Quispe
1
S/ 16.50
REGISTRADA
7
kim loslo
1
S/ 18.90
6
kim loslo
1
S/ 18.90
5
kim loslo
1
S/ 18.90
Ver
Página 1 de 1 · 4 ventas
Anterior
Siguiente
Elementos
Consola
Grabadora
Fuentes
Red
Rendimiento
Memoria
Aplicación
Seguridad
Lighthouse
AdBlock
Nombre
Estado
Tipo
Iniciador
Tamaño
Hora
7/17 solicitudes
11,2 kB/241 kB transferidos
9,1 kB/237 kB recursos
Novedades
Asistencia de IA
Problemas
Buscar
Angular is running in development mode.


Iniciar sesión
Consulta de ventas
Pregunta a Gemini
localhost:4200/login
PharmaSoft
Iniciar sesión
Usuario
vendedor
Contraseña
Mostrar contraseña
Ingresar

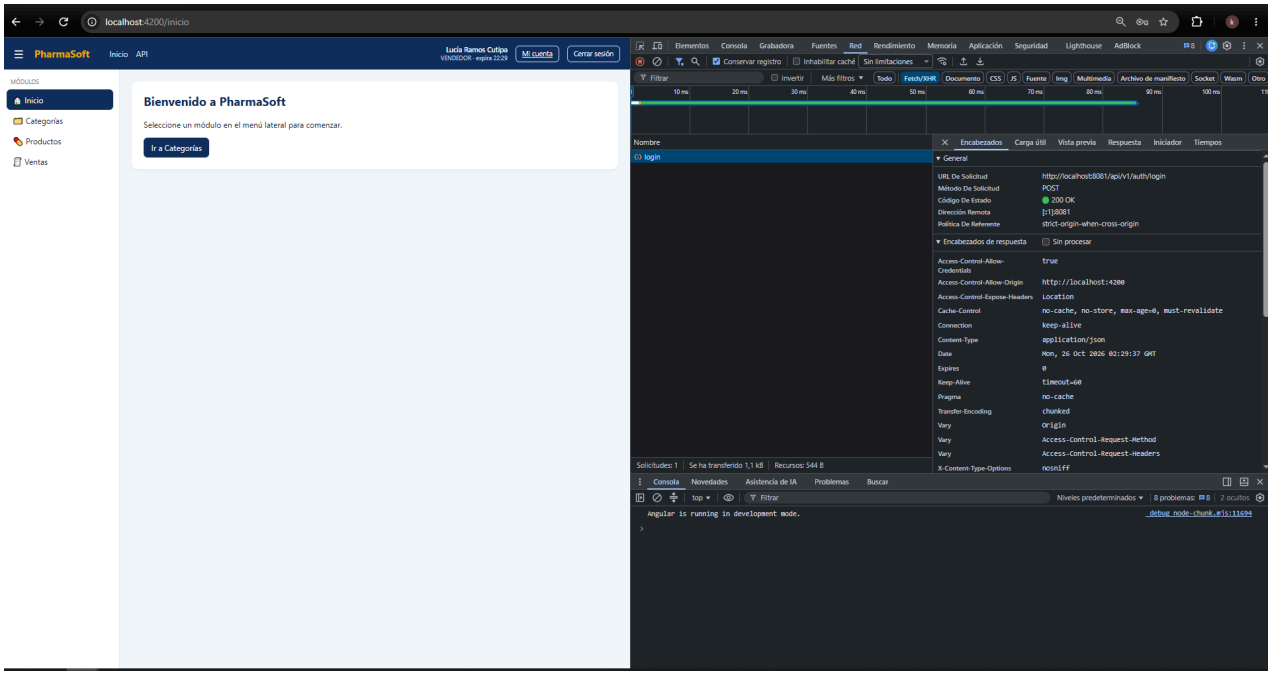


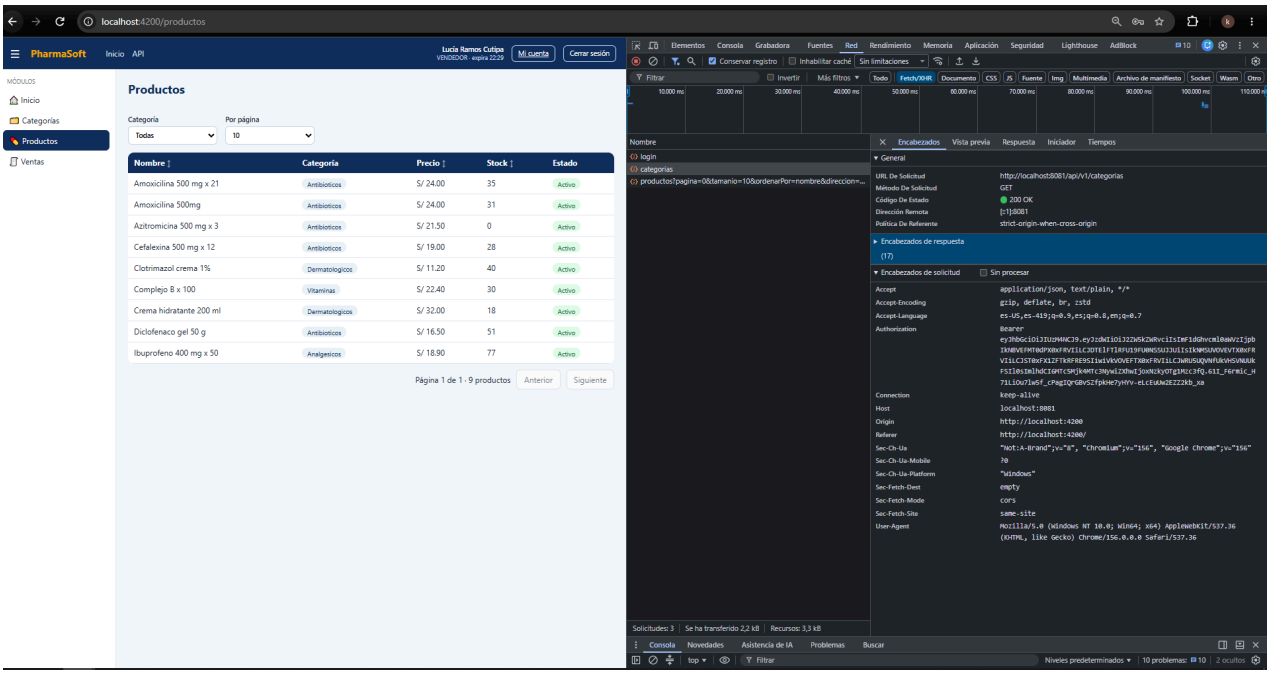
Prueba 9

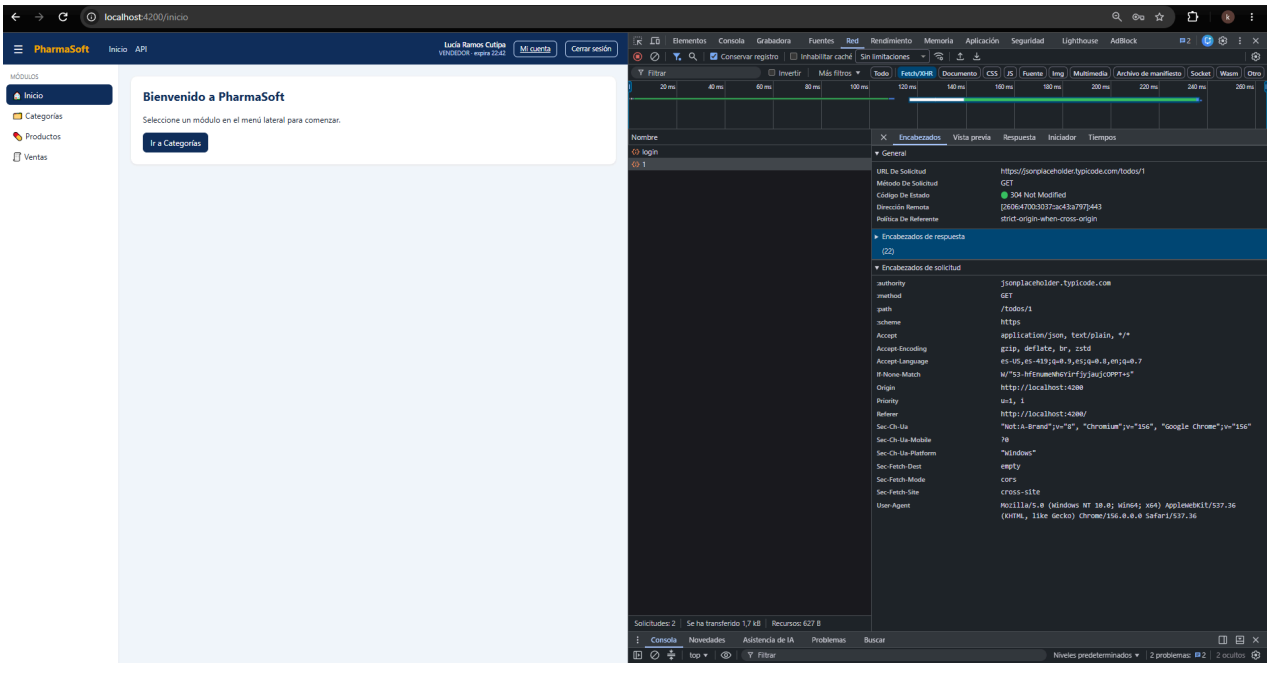
Usuario / token: I-01 Interceptor

Petición: Revisar en Red `GET /productos`, `POST /auth/login` y una petición a otro dominio (por ejemplo, una fuente o imagen externa).

Resultado esperado: Solo las peticiones a la API llevan `Authorization: Bearer`.





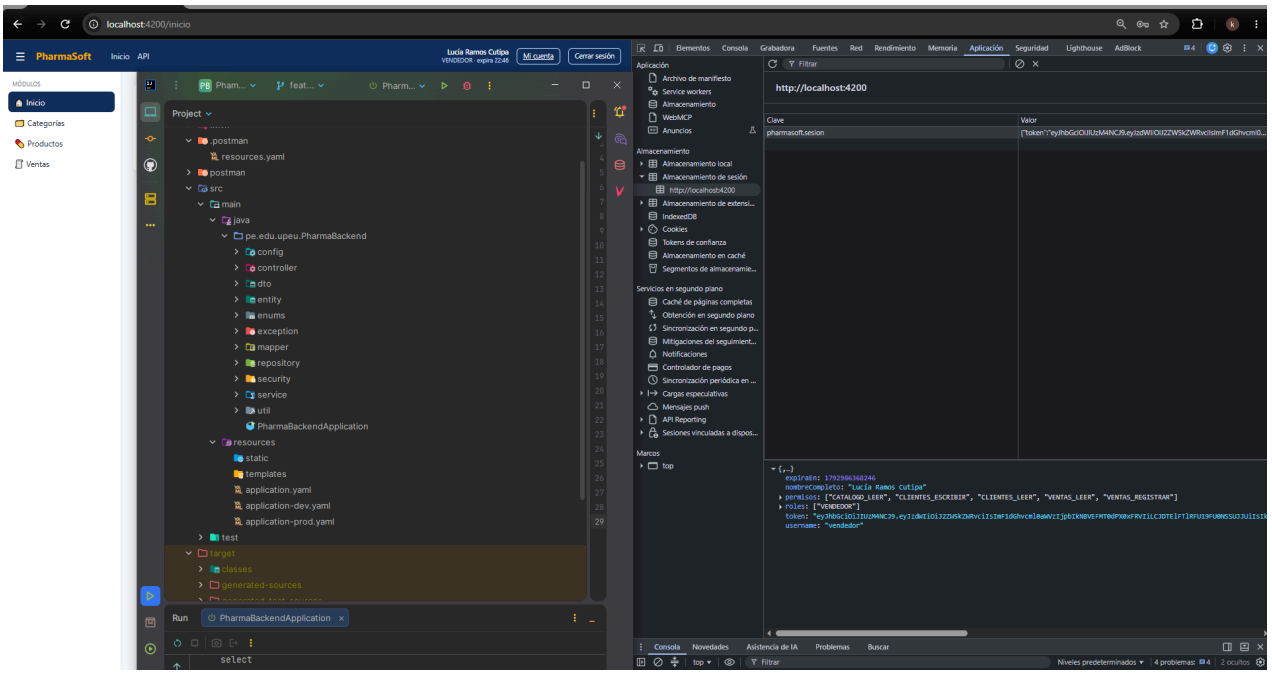


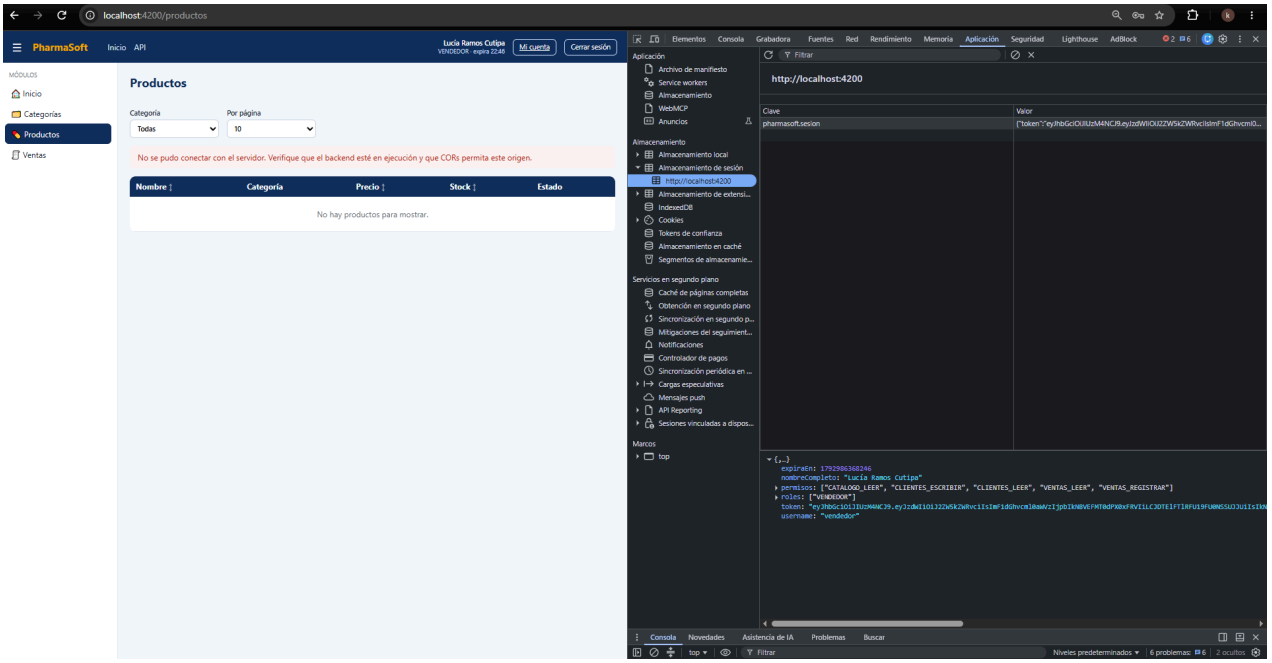
Prueba 10

Usuario / token: I-02 Interceptor

Petición: Con sesión iniciada, detener el backend y navegar a Productos.

Resultado esperado: Mensaje de error de conexión; la sesión no se cierra (no es un 401)


localhost:4200/inicio
PharmaSoft
Inicio
API
Lucía Ramos Cutipa
VENDEDOR · expira 22:46
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Ventas
Project
.postman
resources.yaml
postman
src
main
java
pe.edu.upeu.PharmaBackend
config
controller
dto
entity
enums
exception
mapper
repository
security
service
util
PharmaBackendApplication
resources
static
templates
application.yaml
application-dev.yaml
application-prod.yaml
test
target
classes
generated-sources
Run
PharmaBackendApplication
select
Elementos
Consola
Grabadora
Fuentes
Red
Rendimiento
Memoria
Aplicación
Seguridad
Lighthouse
AdBlock
Aplicación
Archivo de manifiesto
Service workers
Almacenamiento
WebMCP
Anuncios
Almacenamiento
Almacenamiento local
Almacenamiento de sesión
http://localhost:4200
IndexedDB
Cookies
Tokens de confianza
Almacenamiento en caché
Segmentos de almacenamie...
Servicios en segundo plano
Caché de páginas completas
Obtención en segundo plano
Sincronización en segundo p...
Mitigaciones del seguimient...
Notificaciones
Controlador de pagos
Sincronización periódica en ...
Cargas especulativas
Mensajes push
API Reporting
Sesiones vinculadas a dispos...
Marcos
top
http://localhost:4200
Clave
Valor
pharmasoft.sesion
{"token":"eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJlZW5kZWRvciIsImF1dGhvcml0...
{,…}
expiraEn: 1792986368246
nombreCompleto: "Lucía Ramos Cutipa"
permisos: ["CATALOGO_LEER", "CLIENTES_ESCRIBIR", "CLIENTES_LEER", "VENTAS_LEER", "VENTAS_REGISTRAR"]
roles: ["VENDEDOR"]
token: "eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJlZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTEIFNUIFNSUJSUiIs

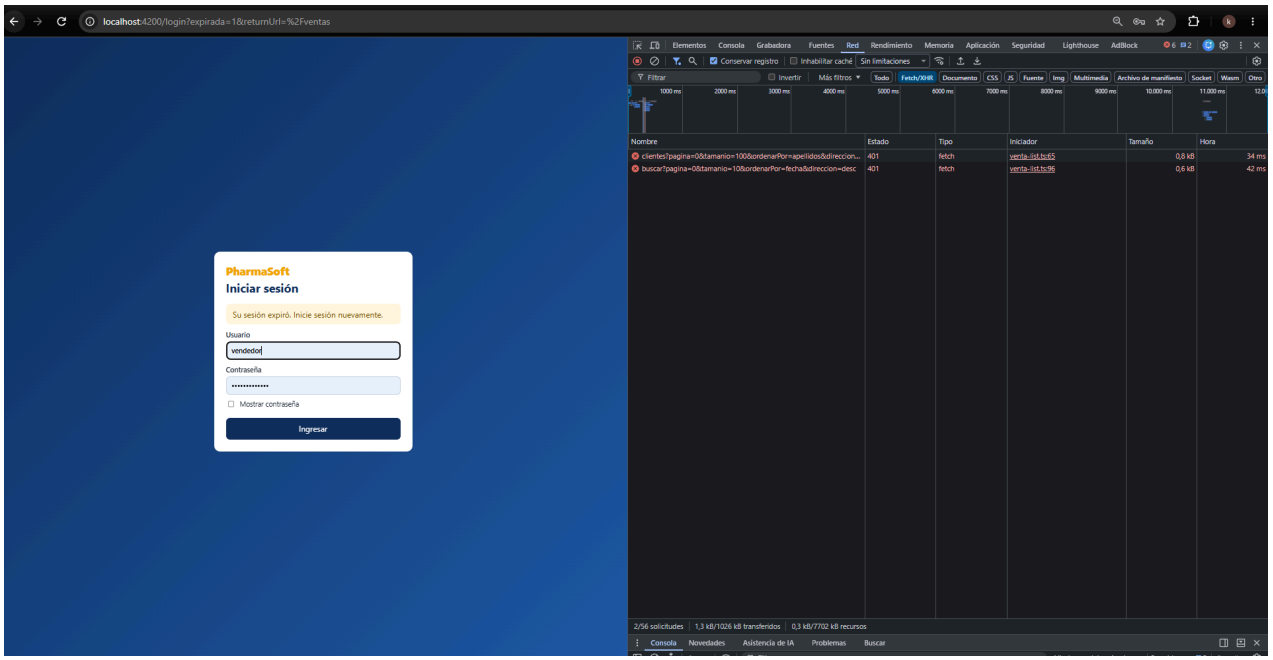


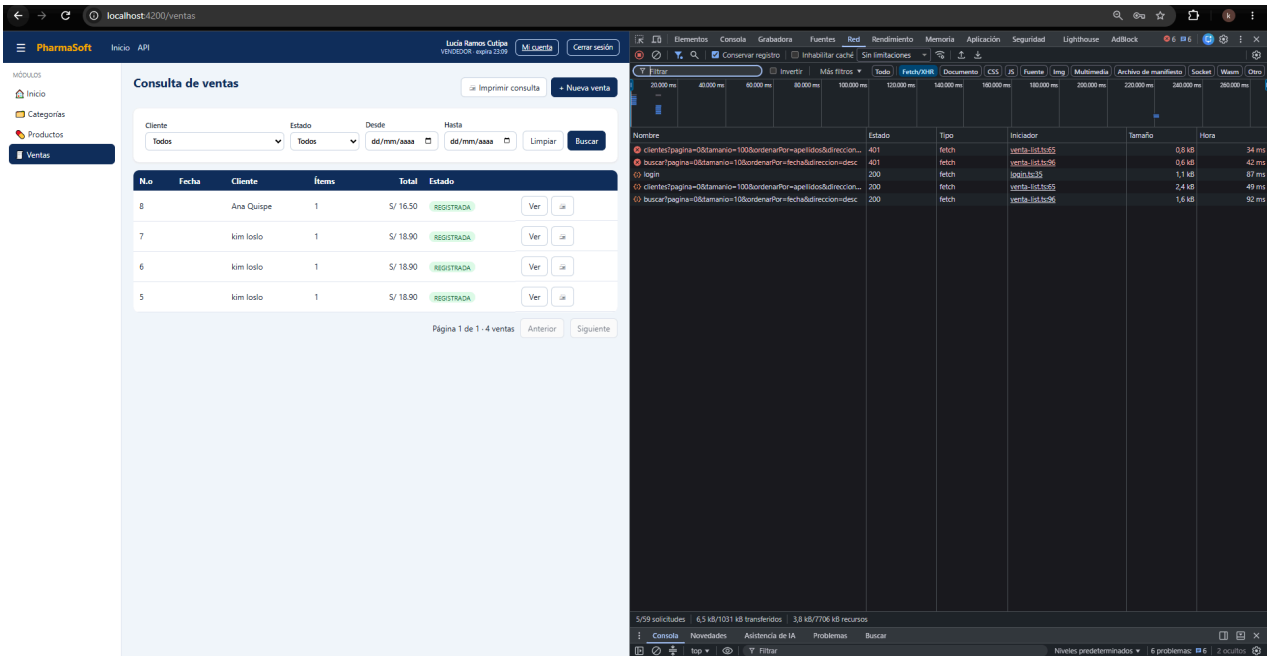
Prueba 11

Usuario / token: I-03 Interceptor

Petición: Alterar un carácter del token y abrir Ventas..

Resultado esperado:401; login con «Su sesión expiró» y `returnUrl=%2Fventas`.



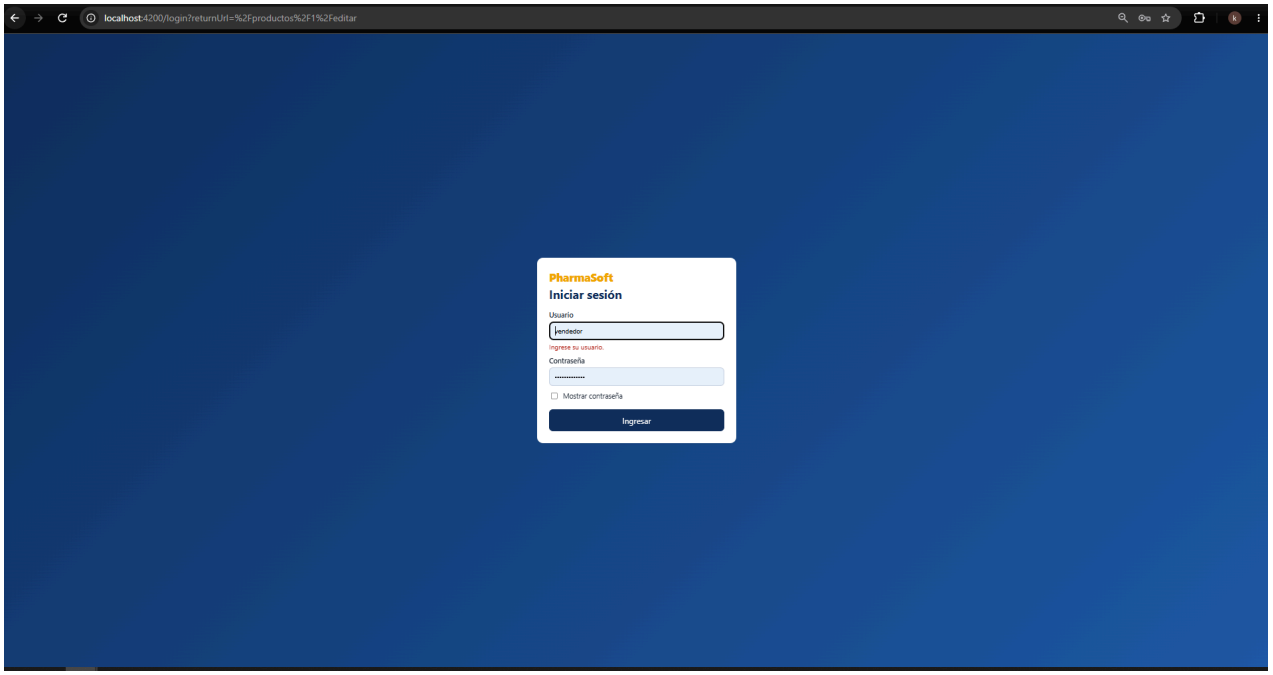


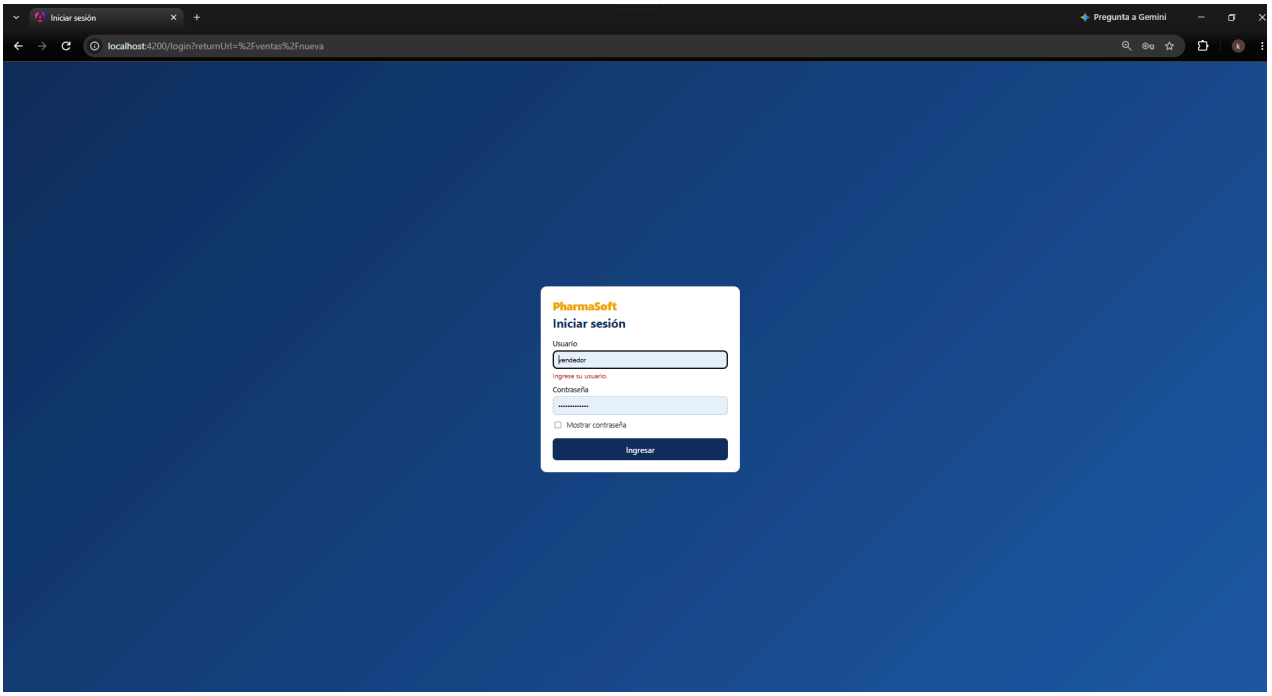
Prueba 12

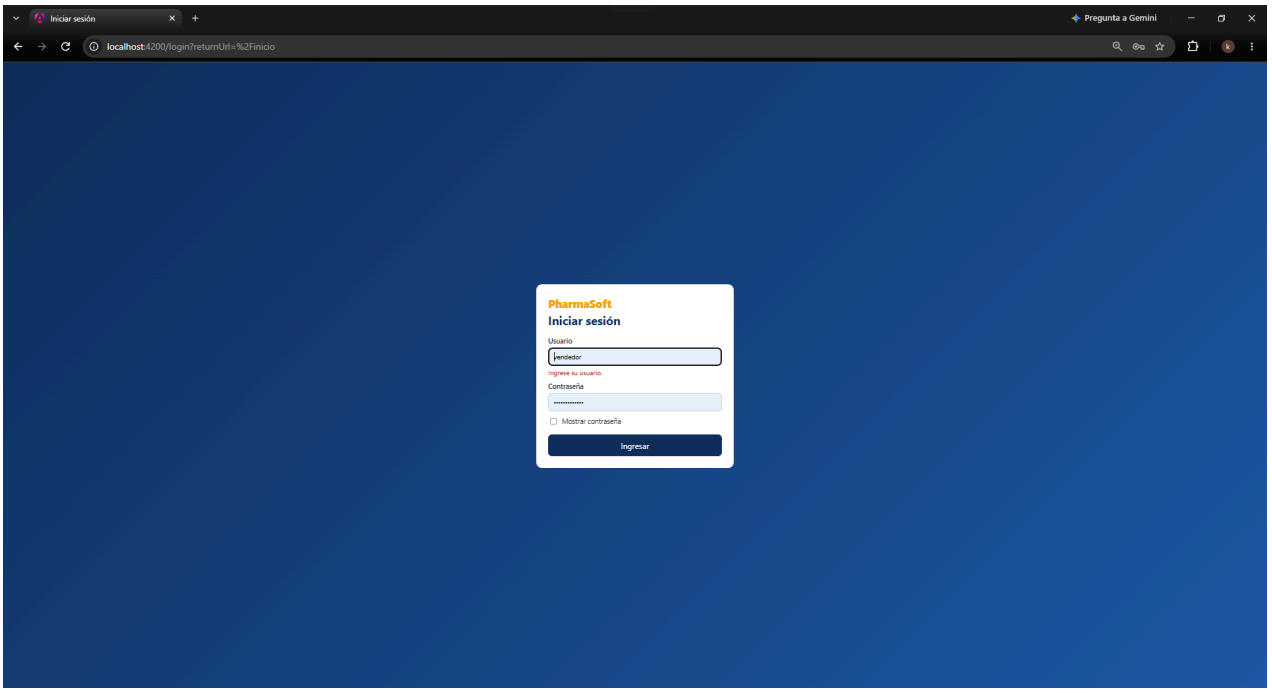
Usuario / token: G-01 Guards

Petición: Sin sesión, escribir `/productos/1/editar`, `/ventas/nueva` e `/inicio`.

Resultado esperado: Login con el `returnUrl` de cada ruta.

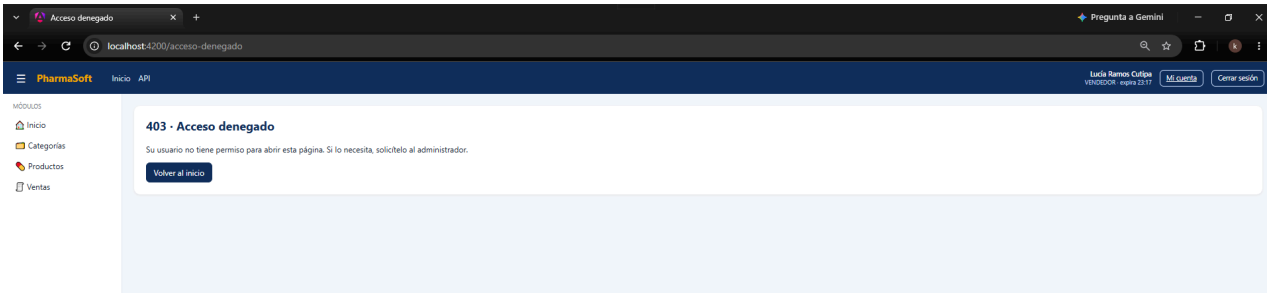

localhost:4200/login?returnUrl=%2Fproductos%2F1%2Feditar
PharmaSoft
Iniciar sesión
Usuario
jendedor
Ingrese su usuario.
Contraseña
Mostrar contraseña
Ingresar

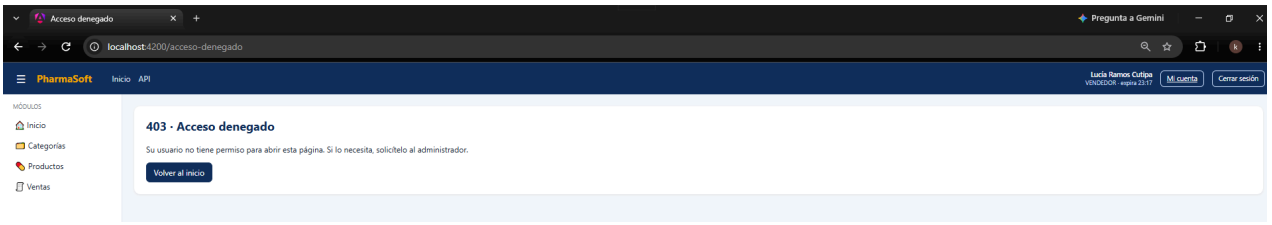

Iniciar sesión
Pregunta a Gemini
localhost:4200/login?returnUrl=%2Fventas%2Fnueva
PharmaSoft
Iniciar sesión
Usuario
jendedor
Ingrese su usuario.
Contraseña
Mostrar contraseña
Ingresar



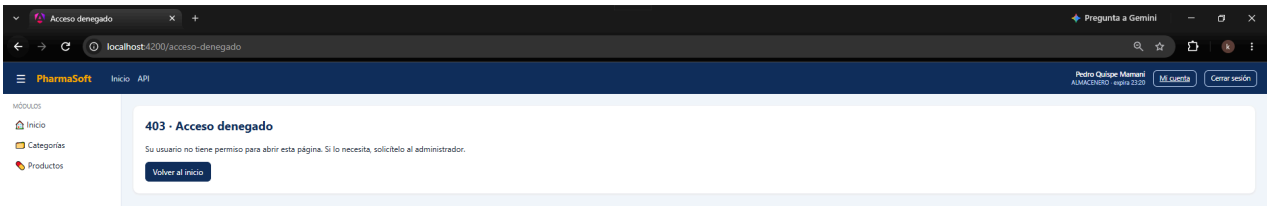
Prueba 13
Usuario / token: G-02 Guards
Petición:VENDEDOR escribe `/categorias/nuevo`, `/productos/1/editar`; ALMACENERO escribe `/ventas/nueva`.
Resultado esperado:«403 · Acceso denegado» en los tres casos.

VENDEDOR escribe `/categorias/nuevo`, `/productos/1/editar`;



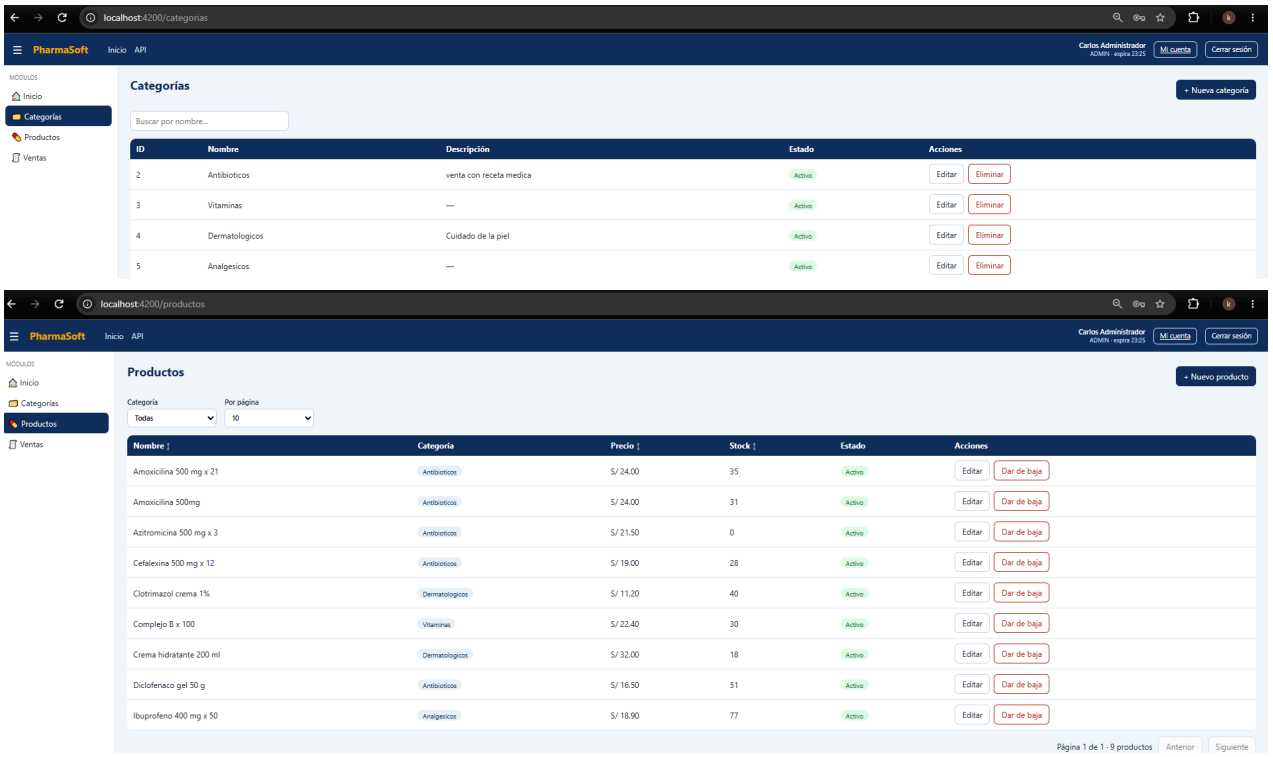


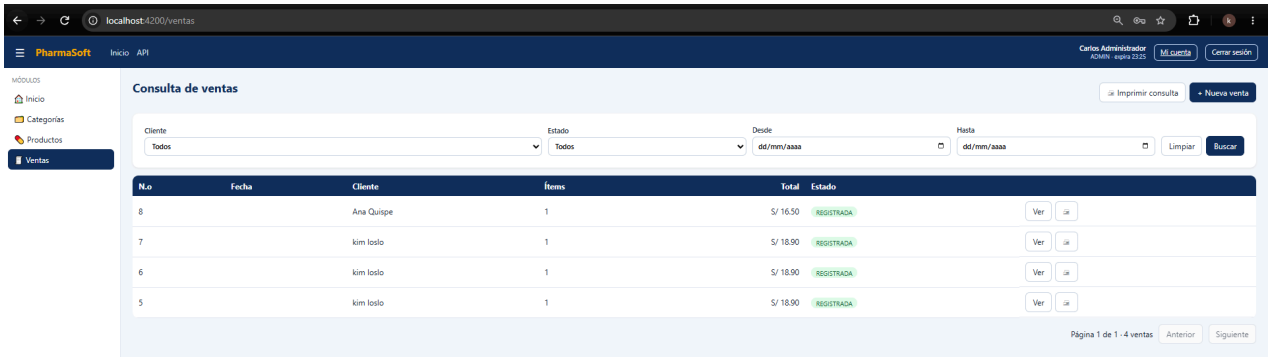
ALMACENERO escribe `/ventas/nueva`.



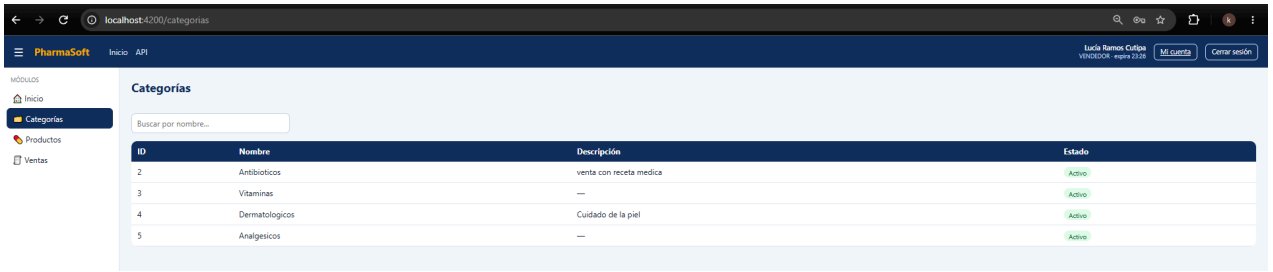
Prueba 14
Usuario / token: M-01 Menú y acciones
Petición: Iniciar sesión con los cuatro usuarios activos y comparar menú y botones.
Resultado esperado:«403 · Cada usuario ve exactamente lo que indica su tabla de permisos

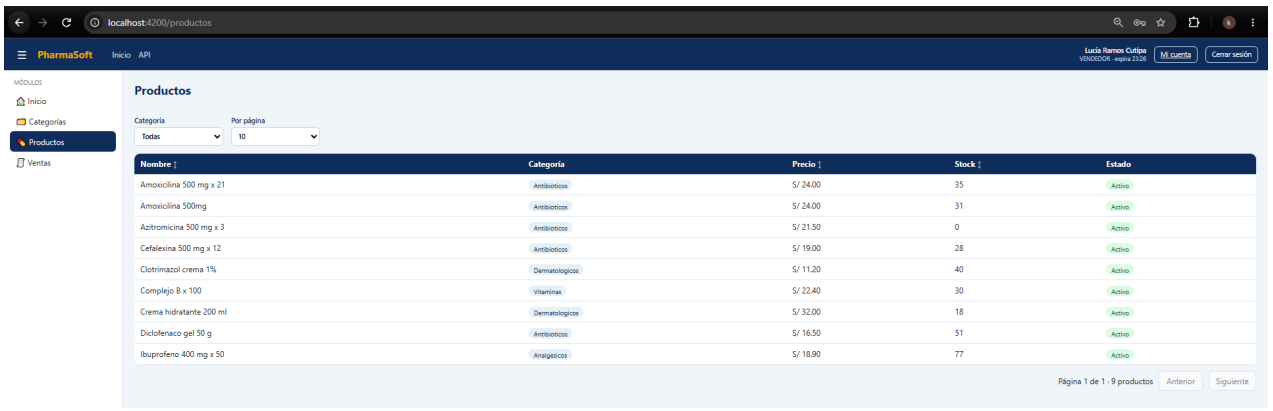
ADMIN

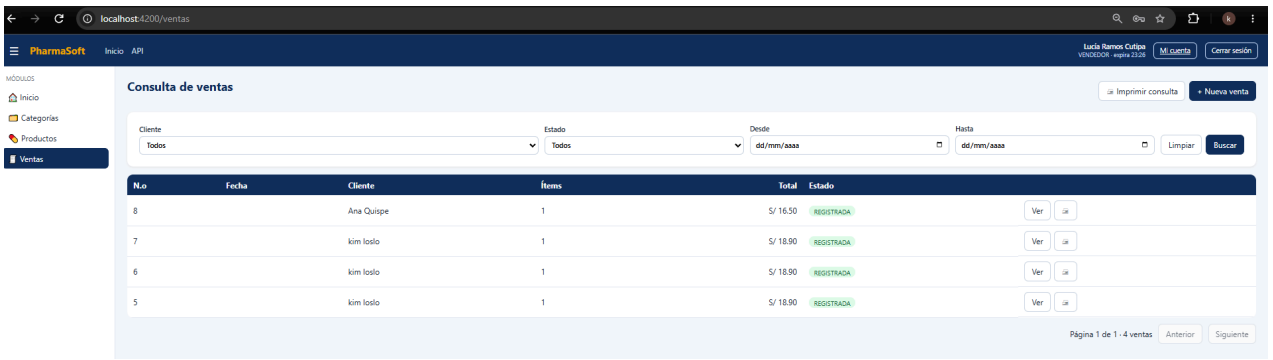




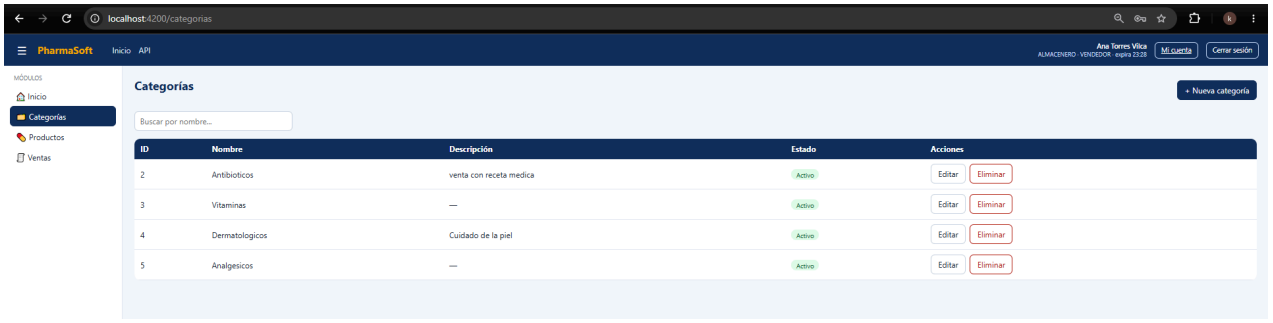
VENDEDOR

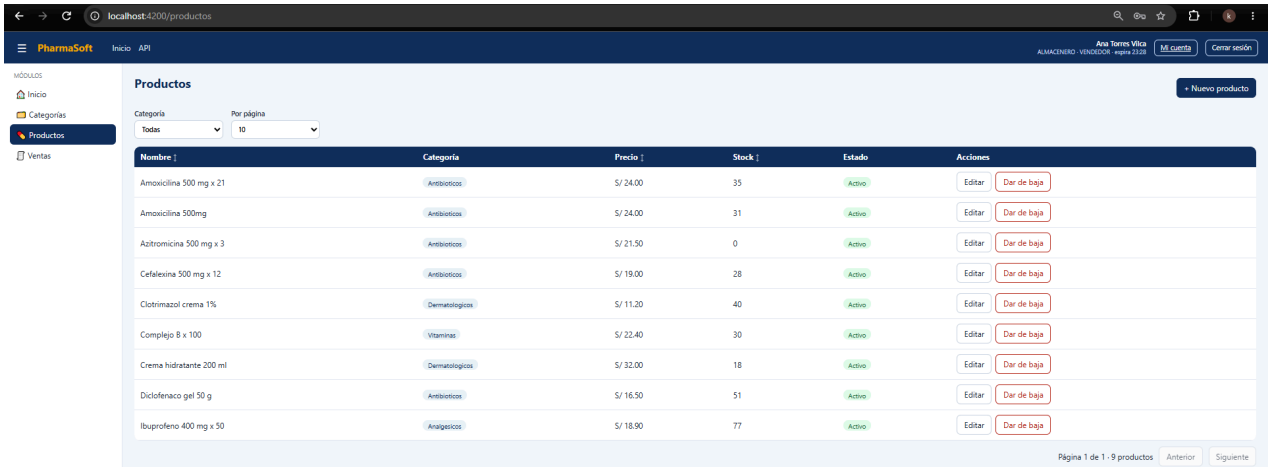


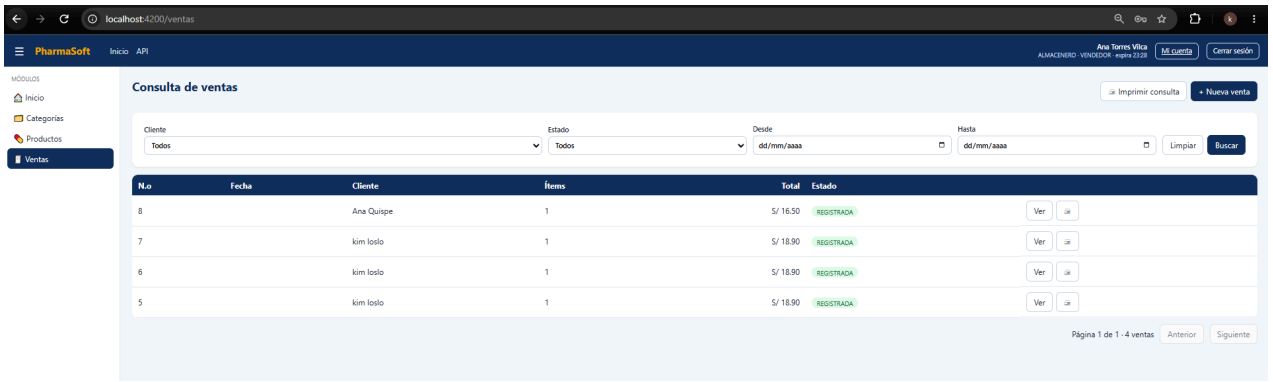




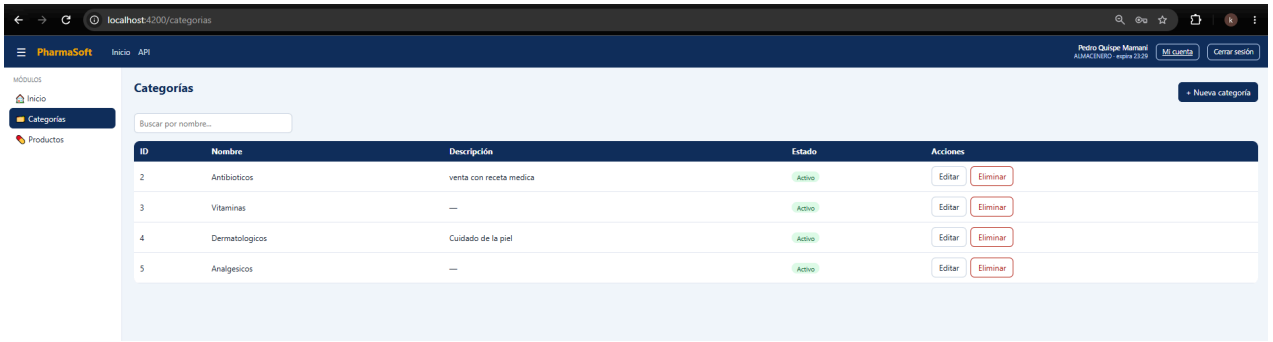
SUPERVISOR

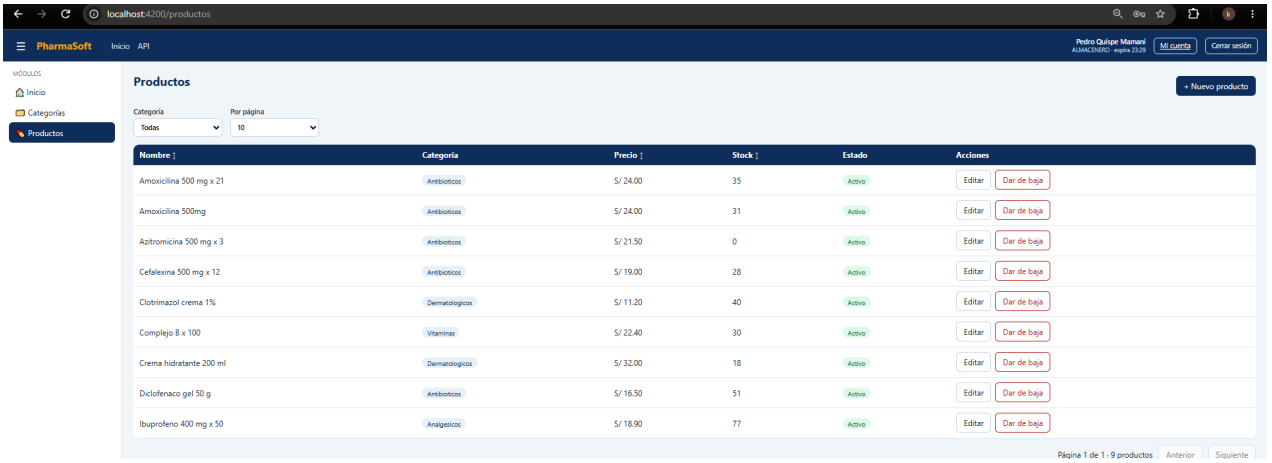

localhost:4200/categorias
PharmaSoft
Inicio
API
Ana Torres Vilca
ALMACENERO · VENDEDOR · expira 23:28
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Ventas
Categorías
+ Nueva categoría
Buscar por nombre...
ID
Nombre
Descripción
Estado
Acciones
2
Antibioticos
venta con receta medica
Activo
Editar
Eliminar
3
Vitaminas
—
Activo
Editar
Eliminar
4
Dermatologicos
Cuidado de la piel
Activo
Editar
Eliminar
5
Analgesicos
—
Activo
Editar
Eliminar


localhost:4200/productos
PharmaSoft
Inicio
API
Ana Torres Vilca
ALMACENERO · VENDEDOR · expira 23:28
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Ventas
Productos
+ Nuevo producto
Categoría
Todas
Por página
10
Nombre
Categoría
Precio
Stock
Estado
Acciones
Amoxicilina 500 mg x 21
Antibioticos
S/ 24.00
35
Activo
Editar
Dar de baja
Amoxicilina 500mg
Antibioticos
S/ 24.00
31
Activo
Editar
Dar de baja
Azitromicina 500 mg x 3
Antibioticos
S/ 21.50
0
Activo
Editar
Dar de baja
Cefalexina 500 mg x 12
Antibioticos
S/ 19.00
28
Activo
Editar
Dar de baja
Clotrimazol crema 1%
Dermatologicos
S/ 11.20
40
Activo
Editar
Dar de baja
Complejo B x 100
Vitaminas
S/ 22.40
30
Activo
Editar
Dar de baja
Crema hidratante 200 ml
Dermatologicos
S/ 32.00
18
Activo
Editar
Dar de baja
Diclofenaco gel 50 g
Antibioticos
S/ 16.50
51
Activo
Editar
Dar de baja
Ibuprofeno 400 mg x 50
Analgesicos
S/ 18.90
77
Activo
Editar
Dar de baja
Página 1 de 1 · 9 productos
Anterior
Siguiente


localhost:4200/ventas
PharmaSoft
Inicio
API
Ana Torres Vilca
ALMACENERO · VENDEDOR · expira 23:28
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Ventas
Consulta de ventas
Imprimir consulta
+ Nueva venta
Cliente
Todos
Estado
Todos
Desde
dd/mm/aaaa
Hasta
dd/mm/aaaa
Limpiar
Buscar
N.o
Fecha
Cliente
Ítems
Total
Estado
8
Ana Quispe
1
S/ 16.50
REGISTRADA
Ver
7
kim loslo
1
S/ 18.90
REGISTRADA
Ver
6
kim loslo
1
S/ 18.90
REGISTRADA
Ver
5
kim loslo
1
S/ 18.90
REGISTRADA
Ver
Página 1 de 1 · 4 ventas
Anterior
Siguiente

ALMACEN


localhost:4200/categorias
PharmaSoft
Inicio
API
Pedro Quispe Mamani
ALMACENERO · expira 23:29
Mi cuenta
Cerrar sesión
MÓDULOS
Inicio
Categorías
Productos
Categorías
+ Nueva categoría
Buscar por nombre...
ID
Nombre
Descripción
Estado
Acciones
2
Antibioticos
venta con receta medica
Activo
Editar
Eliminar
3
Vitaminas
—
Activo
Editar
Eliminar
4
Dermatologicos
Cuidado de la piel
Activo
Editar
Eliminar
5
Analgesicos
—
Activo
Editar
Eliminar

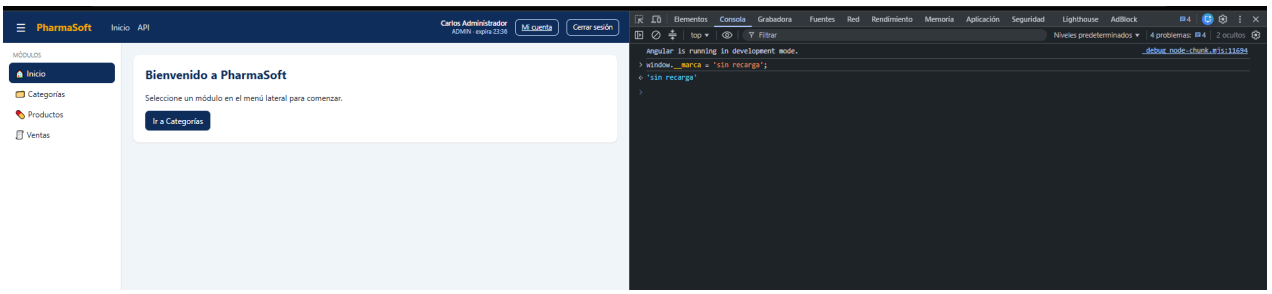


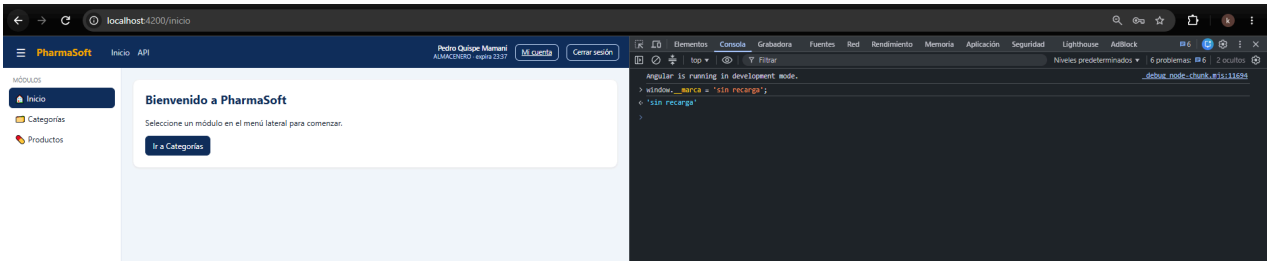
Prueba 15

Usuario / token: M-02 Menú y acciones

Petición: Cerrar sesión como ADMIN e iniciar como ALMACENERO sin recargar.

Resultado esperado: El menú cambia sin F5 (computed).



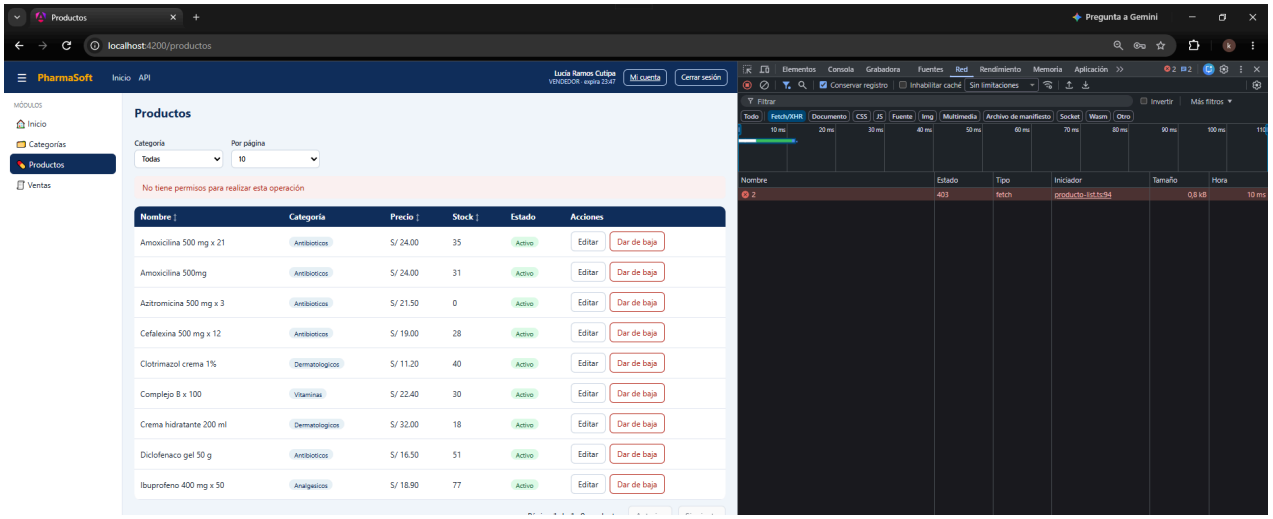


Prueba 16

Usuario / token: E-01 401 / 403

Petición: Como VENDEDOR, quitar `*appSiPermiso` del botón «Dar de baja» (o usar la consola) y ejecutar la acción

Resultado esperado: El backend responde 403; la SPA muestra el mensaje y la sesión continúa.



Parte B. Aviso previo a la expiración y página «Mi cuenta» (7 puntos)

B1. Aviso previo a la expiración (4 puntos). Cuando falten **dos minutos** para que el token venza, la SPA muestra un aviso fijo sobre el contenido:

```
⚠ Su sesión vence en 01:47. [ Cerrar sesión ahora ] [ × ]
```

- En `AuthService` agrega un signal `segundosRestantes` y un `computed porVencer` (verdadero cuando quedan 120 segundos o menos y hay sesión). Actualiza el signal con un `setInterval` de un segundo que se detiene al cerrar la sesión.
- Crea el componente standalone `shared/components/aviso-sesion` que muestra el aviso solo si `porVencer()`, con la cuenta regresiva en formato `mm:ss`.
- El botón «Cerrar sesión ahora» llama a `cerrarSesion()`; la «×» oculta el aviso hasta la siguiente sesión (otro signal).
- Colócalo en `main-layout.html`, encima de `<router-outlet />`, con `role="status"` para los lectores de pantalla.
- El temporizador debe limpiarse siempre (`clearInterval`) al cerrar la sesión, para que no queden temporizadores huérfanos.
- Prueba con `app.jwt.expiracion-minutos: 3` en el backend y agrega los casos B-01 a B-04 a tu matriz: aparece a los 2 minutos, la cuenta regresiva avanza, «×» lo oculta y al llegar a cero la SPA vuelve al login.

> **No renueves el token desde el frontend**
>
> El backend de la sesión 10 no tiene un endpoint para renovar el token, así que el aviso solo informa. No intentes «alargar» la sesión cambiando `expiraEn` en el navegador: el backend validará la fecha `exp` firmada dentro del token y responderá 401.

B2. Página «Mi cuenta» (3 puntos). Todo usuario autenticado puede ver sus datos tal como los conoce el servidor:

```
GET /api/v1/auth/me (requiere token, cualquier rol)
→ 200 { username, nombreCompleto, roles: [...], permisos: [...] }
```

- Ruta `/mi-cuenta` dentro del layout (protegida por `authGuard`, sin `permisoGuard`), con `loadComponent` y título «Mi cuenta».
- Agrega a `AuthService` el método `obtenerPerfil()` que llama a `/auth/me`; el componente `features/auth/pages/mi-cuenta` lo consume con estados de carga y error.
- Muestra el nombre completo, el usuario, los roles como etiquetas y los permisos agrupados por módulo (Catálogo, Clientes, Ventas, Reportes, Usuarios) con una marca ✔ o ✘.
- Agrega un enlace «Mi cuenta» en el encabezado, junto al nombre del usuario.
- Compara los permisos de `/auth/me` con los guardados en la sesión. Si son distintos (por ejemplo, porque el administrador cambió los roles), muestra un aviso: «Sus permisos cambiaron. Cierre sesión y vuelva a ingresar para actualizarlos».

Parte C. Informe de seguridad del frontend (3 puntos)

Redacta un informe breve (2 a 3 páginas) con:

- **C1. Resumen:** casos ejecutados, cuántos pasan y cuántos fallan por grupo.
- **C2. Fichas de hallazgos:** una por caso que falla, con descripción, severidad, evidencia, causa probable (archivo y método) y corrección propuesta.
- **C3. Preguntas de análisis**, respondidas en un párrafo cada una:

1. Si el menú, la directiva y los guards ya ocultan lo que el usuario no puede hacer, ¿por qué el backend debe seguir validando cada permiso? Usa el caso E-01 como evidencia.
2. ¿Qué ventajas y riesgos tiene guardar el token en `sessionStorage` frente a `localStorage` y a una cookie `HttpOnly`? ¿Cuál elegirías para la botica y por qué?
3. ¿Por qué el `errorInterceptor` cierra la sesión ante un 401 pero no ante un 403? ¿Qué pasaría con la experiencia del usuario si se hiciera al revés?
4. ¿Qué es una redirección abierta y cómo la evita la validación del `returnUrl` en el login? Explícalo con el caso L-04.

Parte D. Versionamiento y entrega (2 puntos)

- Al menos tres commits en días distintos en `feature/seguridad-spa-pruebas-<apellido>`; por ejemplo: `test(auth): matriz de pruebas de la SPA segura`, `feat(auth): aviso previo a la expiración de la sesión`, `feat(auth): página Mi cuenta con /auth/me`.
- Guarda en el repositorio `docs/matriz-seguridad-spa-s11.xlsx` (o `.md`) y `docs/informe s11.pdf`. Ninguna captura ni archivo debe contener un token completo.

- Abre una solicitud de incorporación hacia `develop` y sube el informe al aula virtual como `Apellido_LP2_S11_Autonoma.pdf`.

Producto esperado

- Matriz con al menos 20 casos ejecutados (más B-01 a B-04), con resultado esperado y obtenido, estado y evidencia.
- Aviso previo a la expiración con cuenta regresiva y página «Mi cuenta» funcionando según sus reglas.

Informe de seguridad del frontend con las secciones C1 a C3.

- Rama con al menos tres commits y solicitud de incorporación hacia `develop`.

Lista de cotejo

1	La matriz tiene al menos 20 casos, con los 16 base y 4 propios de grupos distintos.	2		
2	Cada caso indica pasos, resultado esperado y obtenido, y su estado.	2		
3	Los casos de sesión e interceptor (F5, sesión vencida o dañada, token alterado, backend detenido) están ejecutados con evidencia.	2		
4	Los casos de guards, menú y 403 cubren los cuatro usuarios activos y distinguen 401 de 403.	1		
5	Cada caso tiene su evidencia nombrada con el ID y ninguna muestra un token completo.	1		
6	El aviso aparece cuando quedan dos minutos o menos y muestra la cuenta regresiva en mm:ss.	1.5		
7	El aviso permite cerrar sesión u ocultarse, y el temporizador se limpia al cerrar la sesión.	1.5		
8	La página «Mi cuenta» está protegida, consume `/auth/me` con estados de carga y error, y muestra roles y permisos por módulo.	2		
9	«Mi cuenta» detecta cuando los permisos del servidor difieren de los de la sesión.	1		
10	Las fichas de hallazgos indican causa probable y corrección propuesta.	1.5		
11	Las cuatro preguntas de análisis se responden con argumentos y referencias al código.	1.5		
12	La rama tiene al menos tres commits en días distintos, los documentos en `docs/` y la solicitud de incorporación.	2		
	Total	**20**		

3. Criterios de entrega

- Plazo: **28 de octubre de 2026, 23:59**. En la sesión 12 (29 de octubre) se realiza la evaluación de la Unidad II y la sustentación de la SPA segura: esta actividad es tu ensayo.

- Las entregas tardías se califican sobre el 70 % del puntaje, hasta 24 horas después del plazo.

- Una matriz cuyos resultados no coincidan con las evidencias, o un repositorio sin commits propios, se califica con cero.
- Puedes usar asistentes de inteligencia artificial para consultar dudas, pero en la sustentación el docente podrá pedirte que repitas cualquier caso o expliques cualquier línea de tu código.

4. Dudas frecuentes

¿Cómo calculo los segundos restantes?	`Math.max(0, Math.floor((sesion.expiraEn - Date.now()) / 1000))`. `expiraEn` ya está en milisegundos desde el login.
¿Cómo muestro mm:ss?	Minutos = `Math.floor(s / 60)` y segundos = `s % 60`; completa con `String(n).padStart(2, '0')`.
El aviso no se actualiza cada segundo.	El valor debe estar en un signal que el `setInterval` actualice; un número normal no avisa a la plantilla en una aplicación zoneless.
¿`/auth/me` necesita algún código especial para enviar el token?	No: el `authInterceptor` ya lo agrega porque la URL empieza con `environment.apiUrl`.
¿Cómo cambio los roles de un usuario para probar el aviso de «Mi cuenta»?	Como ADMIN, usa en Swagger el endpoint de la actividad autónoma de la sesión 10 (o edita `usuario_roles` en SQL Developer) y abre «Mi cuenta» con la sesión anterior.
En S-04 la otra pestaña sigue con sesión. ¿Está mal?	No necesariamente: `sessionStorage` es independiente por pestaña. Explica en el informe la consecuencia y cómo lo resolverías (por ejemplo, con el evento `storage` o `BroadcastChannel`).
¿Debo modificar el backend?	No. Solo cambia temporalmente `app.jwt.expiracion-minutos` para probar y restaura el valor 60 al terminar.

Cuando termines, la pregunta con la que empezó la sesión tendrá una respuesta completa. En el Reto 01 conectaste PharmaSoft al backend seguro: login, sesión con vencimiento, interceptores, guards y un menú que se adapta a cada trabajador. En el Reto 02 demostraste, con casos medidos, que la SPA reacciona bien ante un token alterado o vencido, que una URL escrita a mano no abre lo que no corresponde y que, aunque alguien fuerce un botón oculto, el backend sigue diciendo que no. Y además la botica ya no pierde una venta por una sesión que vence sin aviso.

5. Referencias

Angular. (s. f.-a). *Route guards*. https://angular.dev/guide/routing/route-guards

Angular. (s. f.-b). *Signals*. https://angular.dev/guide/signals

MDN Web Docs. (s. f.). *Window: sessionStorage property*. https://developer.mozilla.org/en-US/docs/Web/API/Window/sessionStorage

OWASP Foundation. (s. f.). *Session management cheat sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Session*Management*Cheat_Sheet.html